

**R O M Â N I A**  
**MINISTERUL EDUCAȚIEI**  
**UNIVERSITATEA DIN CRAIOVA**  
**FACULTATEA DE ECONOMIE ȘI ADMINISTRAREA AFACERILOR**

*Craiova, Str. A.I. Cuza, nr. 13, 200585, tel/fax: +40-251-411317,  
<http://feaa.ucv.ro>*

**Programul de studii: Informatică Economică**  
**Forma de învățământ: Cu frecvență (IF)**

**LUCRARE DE LICENȚĂ**

**ARHITECTURA ȘI SECURITATEA SISTEMELOR INFORMATICE BANCARE:**  
**PROIECTAREA, IMPLEMENTAREA ȘI AUDITUL REZILIENȚEI CIBERNETICE ÎNTR-UN MEDIU VIRTUALIZAT**

---

|                                    |                        |
|------------------------------------|------------------------|
| <b>Coordonator științific,</b>     | <b>Absolvent,</b>      |
| Conf. univ. dr. [Nume Coordonator] | Moanță Ștefanuț-Cornel |

---

**Craiova**  
**2026**

**CUPRINS**

**INTRODUCERE ..... 3**

**CAPITOLUL 1. STADIUL CUNOAȘTERII ÎN SECURITATEA CIBERNETICĂ BANCARĂ ..... 5**

1.1. Cadrul de reglementare și conformitate în sectorul bancar european și național ..... 5

1.1.1. Directiva Revizuită privind Serviciile de Plată (PSD2) și Cerințele EBA RTS ..... 5

1.1.2. Regulamentul DORA (Digital Operational Resilience Act - UE 2022/2554) ..... 7

1.1.3. Standardul de Securitate a Datelor din Industria Cardurilor (PCI-DSS v4.0) ..... 9

1.1.4. Standardul ISO 20022 și Reglementările Băncii Naționale a României (BNR) ..... 11

1.2. Arhitectura sistemelor informatice financiar-bancare ..... 13

1.2.1. Sistemele de Core-Banking și Registrul General în Partidă Dublă ..... 13

|                                                                                                                             |           |
|-----------------------------------------------------------------------------------------------------------------------------|-----------|
| 1.2.2. Porțile de Plată Electronice (Payment Gateways) și Procesarea Tranzacțiilor .....                                    | 15        |
| 1.2.3. Comunicațiile Interbancare și Rețeaua SWIFT .....                                                                    | 17        |
| 1.3. Vectori de atac contemporani și analiza amenințărilor în sectorul bancar .....                                         | 19        |
| 1.3.1. Manipularea Bazelor de Date și Atacurile de tip SQL Injection .....                                                  | 19        |
| 1.3.2. Fraudele Tranzacționale: Card Stuffing, Velocity Floods și Credential Stuffing .....                                 | 21        |
| 1.3.3. Mișcarea Laterală, Compromiterea Nodurilor Administrative și Infostealers .....                                      | 23        |
| 1.3.4. Alterarea Mesageriei Financiare și Campaniile Ransomware cu Dublă Extorcare .....                                    | 25        |
| 1.4. Principii și mecanisme de securitate defensivă bancară .....                                                           | 27        |
| 1.4.1. Paradigma Zero Trust (ZTA) și Principiul Privilegiului Minim (PoLP) .....                                            | 27        |
| 1.4.2. Segmentarea Rețelei, VLAN-uri și Firewalling Stateful cu Inspecție Profundă .....                                    | 29        |
| 1.4.3. Monitorizarea Integrității Datelor și Sistemele HIDS/SIEM (Wazuh) .....                                              | 31        |
| 1.4.4. Bastioane Administrative (Jump-Box) cu Autentificare Ed25519 și MFA .....                                            | 33        |
| <b>CAPITOLUL 2. PROIECTAREA, IMPLEMENTAREA ȘI EVALUAREA ARHITECTURII BANCARE REZILIENTE ÎNTR-UN MEDIU VIRTUALIZAT .....</b> | <b>35</b> |
| 2.1. Arhitectura generală și topologia laboratorului virtual bancar .....                                                   | 35        |
| 2.1.1. Platforma de Virtualizare Proxmox VE 9.2 și Dimensionarea Resurselor .....                                           | 35        |
| 2.1.2. Segmentarea Rețelei prin Firewall OPNsense și Politici Inter-VLAN .....                                              | 37        |
| 2.2. Implementarea componentelor bancare fundamentale .....                                                                 | 39        |
| 2.2.1. Mașina Virtuală Core-Banking Engine (VM 310) și Ledger-ul Criptografic .....                                         | 39        |
| 2.2.2. Mașina Virtuală Financial Database (VM 311) și Motorul de Audit Wazuh .....                                          | 43        |
| 2.2.3. Containerul LXC Payment Gateway & SWIFT Simulator (CT 312) .....                                                     | 47        |

|                                                                                                          |           |
|----------------------------------------------------------------------------------------------------------|-----------|
| 2.2.4. Mașina Virtuală SWIFT Jump-Box (VM 313) cu Securitate Sporită .....                               | 51        |
| 2.3. Scenarii experimentale de atac, simulare și validare defensivă .....                                | 54        |
| 2.3.1. Scenariul 1: Linia de Bază Tranzacțională Kiosk/Casierie (T1078) .....                            | 54        |
| 2.3.2. Scenariul 2: Atac SQL Injection și Alterare de Sold - Balance Tampering (T1190/T1565) .....       | 56        |
| 2.3.3. Scenariul 3: Atac de tip Card Stuffing și Velocity Flood pe Poarta de Plăți (T1110) .....         | 59        |
| 2.3.4. Scenariul 4: Tentativă de Mișcare Laterală și Eludare Jump-Box (T1021) .....                      | 61        |
| 2.3.5. Scenariul 5: Falsificarea Mesageriei SWIFT și Coruperea UETR (T1565) .....                        | 63        |
| 2.4. Monitorizarea securității, colectarea telemetriei și corelarea evenimentelor în Wazuh SIEM .....    | 65        |
| 2.5. Evaluarea performanței, a rezilienței cibernetice și a conformității de reglementare .....          | 69        |
| <b>CONCLUZII .....</b>                                                                                   | <b>74</b> |
| <b>BIBLIOGRAFIE .....</b>                                                                                | <b>77</b> |
| <b>ANEXE .....</b>                                                                                       | <b>81</b> |
| Anexa A: Schema SQL DDL a Bazei de Date Financiare și a Registrului Contabil .....                       | 81        |
| Anexa B: Implementarea Motorului de Verificare a Integrității și Detecție a Manipulării Soldurilor ..... | 84        |
| Anexa C: Jurnalul Telemetric de Securitate și Structura Alertelor Wazuh JSON .....                       | 88        |

## INTRODUCERE

Sectorul financiar-bancar traversează în prezent cea mai amplă și accelerată transformare tehnologică din istoria sa modernă. Migrarea accelerată de la modelele bancare tradiționale, bazate pe sucursale fizice și canale de comunicare închise, către ecosisteme financiare digitale descentralizate, platforme de open banking, microservicii în cloud și interfețe de programare a aplicațiilor (API-uri) a redefinit fundamental modul în care instituțiile de credit interacționează cu clienții și cu partenerii de afaceri. Această evoluție a adus beneficii economice substanțiale: tranzacții în timp real, costuri operaționale optimizate, accesibilitate continuă și o eficiență sporită a fluxurilor de capital.

Totuși, digitalizarea extinsă a condus la o expansiune fără precedent a suprafeței de atac. Pentru entitățile rău-intenționate – variind de la grupări de criminali-

tate cibernetică organizată motivate financiar, până la actori statali persistenți avansați (APT – Advanced Persistent Threats) – sistemele informatice bancare reprezintă ținta supremă. O breșă de securitate într-o instituție financiară nu produce doar pierderi patrimoniale directe, ci poate declanșa crize de lichiditate, falimente bancare, erodarea ireversibilă a încrederii publice și chiar instabilitate sistemică la nivel macroeconomic. În acest peisaj operațional ostil, abordările convenționale de securitate, bazate exclusiv pe apărarea perimetrică clasică, s-au dovedit complet inadecvate.

Conștientizând această vulnerabilitate sistemică, organismele internaționale și europene de reglementare au instituit cadre normative extrem de riguroase. Directiva Revizuită privind Serviciile de Plată (PSD2) a impus mecanisme obligatorii de Autentificare Strictă a Clienților (SCA – Strong Customer Authentication) și legături dinamice tranzacționale. Standardul de Securitate a Datelor din Industria Cardurilor de Plată (PCI-DSS v4.0) a stabilit cerințe stricte pentru criptarea și izolarea mediului datelor titularilor de card (CDE). În paralel, noul Regulament European privind Reziliența Operațională Digitală (DORA – Regulamentul UE 2022/2554) obligă instituțiile financiare să demonstreze nu doar existența unor controale defensive, ci capacitatea demonstrabilă de a rezista, de a absorbi șocurile și de a se recupera rapid în urma unor incidente cibernetiche disruptive majore.

Alegerea acestei teme de cercetare este motivată de necesitatea acută de a crea o punte solidă între teoria economică financiar-bancară (evidența contabilă în partidă dublă, decontarea tranzacțiilor, gestiunea riscurilor) și ingineria sistemelor informatice securizate (rețele de calculatoare, sisteme de operare întărite, baze de date tranzacționale și securitate ofensivă/defensivă). În cadrul programului de studii Informatică Economică din cadrul Facultății de Economie și Administrarea Afacerilor a Universității din Craiova, înțelegerea mecanismelor interne care garantează integritatea și confidențialitatea activelor digitale reprezintă o competență fundamentală pentru formarea specialiștilor capabili să gestioneze riscul operațional modern.

Obiectivul principal al prezentei lucrări de licență constă în proiectarea, implementarea completă, testarea experimentală și auditarea unei arhitecturi informatice bancare reziliente, complet virtualizate într-un laborator de cercetare avansat. Pentru îndeplinirea acestui deziderat general, au fost stabilite următoarele obiective specifice de cercetare:

- **Obiectivul 1:** Analiza critică a stadiului actual al cunoașterii privind securitatea cibernetică în mediul bancar, investigând cerințele de conformitate (DORA, PSD2 RTS, PCI-DSS v4.0, ISO 20022), principiile contabile ale sistemelor Core-Banking și vectorii de atac contemporani.
- **Obiectivul 2:** Proiectarea unei topologii de laborator complet virtualizate pe platforma de hypervisor bare-metal Proxmox VE 9.2, bazată pe segmentare logică de rețea prin VLAN-uri (Management,

Services, CyberLab) și firewalling perimetral de ultimă generație prin OPNsense.

- **Obiectivul 3:** Implementarea practică a celor patru active bancare fundamentale: un motor central de Core-Banking (VM 310) inspirat de standardul deschis Apache Fineract cu registru contabil în partidă dublă și înlănțuire criptografică SHA-256 a tranzacțiilor; un server de bază de date relațională (VM 311 - PostgreSQL) cu tabele de audit nealterabile; o poartă de plăți (CT 312) cu validare Luhn, verificare anti-fraudă și suport pentru schemele de mesagerie SWIFT MT103 și ISO 20022 pacs.008; precum și un bastion de acces securizat (VM 313 - Jump-Box) protejat prin chei criptografice Ed25519 și autentificare cu factori multipli (MFA).

- **Obiectivul 4:** Dezvoltarea și executarea unei suite automatizate de simulare a atacurilor cibernetice (Red Team vs. Blue Team) acoperind 5 scenarii critice: de la tranzacționarea nominală de referință, la atacuri de tip SQL Injection și alterare directă de sold (Balance Tampering), atacuri de tip Card Stuffing pe fluxul de autorizare, mișcare laterală și eludare a bastionului administrativ, până la coruperea structurilor de mesagerie interbancară.

- **Obiectivul 5:** Integrarea unui sistem de monitorizare a integrității și detecție a intruziunilor (HIDS/SIEM - Wazuh), configurarea unor reguli analitice de corelare în timp real capabile să identifice decalajele contabile și maparea integrală a incidentelor pe matricea internațională MITRE ATT&CK for Financial Services.

- **Obiectivul 6:** Evaluarea riguroasă a performanței operaționale, a rezilienței la incidente și a gradului de conformitate de reglementare obținut, evidențiind valoarea adăugată a cercetării și impactul economic direct asupra diminuării pierderilor operaționale din fraude.

Metodologia de cercetare adoptată îmbină analiza teoretică și normativă a literaturii de specialitate cu o abordare cantitativă experimentală. Întreaga arhitectură a fost instanțiată pe nodul fizic de calcul x86\_64 bare-metal al infrastructurii de laborator (procesor Intel Core i3-10100F cu 4 nuclee fizice / 8 fire de execuție la 4.30 GHz Turbo, 12 GB memorie RAM DDR4 completată cu subsistem dinamic ZRAM de 6.0 GB lz4 și subsistem de stocare de 512 GB SSD LVM-Thin sub Proxmox VE 9.2). Toate componentele software au fost dezvoltate în limbajul Python 3, utilizând cadre de lucru moderne (FastAPI, SQLite/PostgreSQL, hashlib) și au fost supuse unor teste de penetrare automate riguroase, asigurând reproductibilitatea completă a rezultatelor obținute.

Lucrarea este structurată riguros pe două capitole principale, conform ghidului de elaborare al facultății. Primul capitol, „Stadiul cunoașterii în securitatea cibernetică bancară”, sintetizează fundamentele legislative, arhitecturale, vulnerabilitățile curente și paradigmele defensive de ultimă generație. Al doilea capitol, „Proiectarea, implementarea și evaluarea arhitecturii bancare reziliente

într-un mediu virtualizat”, constituie contribuția originală extinsă a autorului, detaliind construcția mediului experimental, codul sursă al serviciilor bancare, derularea atacurilor controlate, telemetria sistemului SIEM și validarea ipotezelor de cercetare. Lucrarea se încheie cu o secțiune de concluzii, bibliografia consultată și anexe tehnice cuprinzătoare.

## **CAPITOLUL 1. STADIUL CUNOAȘTERII ÎN SECURITATEA CIBERNETICĂ BANCARĂ**

### **1.1. Cadrul de reglementare și conformitate în sectorul bancar european și național**

În sistemul economic contemporan, sectorul bancar este supus celui mai strict și complex regim de reglementare dintre toate ramurile economice. Această realitate derivă din rolul critic pe care băncile îl joacă ca intermediari financiari, administratori ai economiilor populației și garantori ai continuității mecanismelor de plăți și creditare. Într-o piață financiară unică la nivelul Uniunii Europene, riscul cibernetic a încetat să mai fie considerat o simplă problemă tehnică izolată a departamentelor de IT, fiind reîncadrat juridic și prudențial ca un risc operațional major cu potențial de contagiune sistemică.

#### **1.1.1. Directiva Revizuită privind Serviciile de Plată (PSD2) și Cerințele EBA RTS**

Directiva (UE) 2015/2366 a Parlamentului European și a Consiliului (cunoscută sub acronimul PSD2 – Payment Services Directive 2) a reprezentat o piatră de hotar în democratizarea și digitalizarea serviciilor de plată europene. Obiectivul central al directivei a fost stimularea concurenței, susținerea inovației financiare (FinTech) și facilitarea dezvoltării conceptului de Open Banking. Prin intermediul PSD2, băncile au fost obligate legal să deschidă accesul la conturile clienților (Access to Account – XS2A) către furnizorii terți autorizați (TPP – Third Party Providers), clasificați în furnizori de servicii de inițiere a plății (PISP) și furnizori de servicii de informare cu privire la conturi (AISP), prin intermediul unor interfețe de programare a aplicațiilor (API-uri) dedicate și securizate.

Pentru a contracara riscurile inerente deschiderii sistemelor financiare către terți, Autoritatea Bancară Europeană (EBA), în strânsă colaborare cu Banca Centrală Europeană (BCE), a elaborat Standardele Tehnice de Reglementare (RTS – Regulatory Technical Standards, consfințite prin Regulamentul Delegat UE 2018/389). Pilonul fundamental al acestor cerințe tehnice este reprezentat de Autentificarea Strictă a Clienților (SCA – Strong Customer Authentication). Conform Articolului 97 din PSD2, instituțiile de plată trebuie să aplice SCA ori de câte ori plătitorul accesează contul de plăți online, inițiază o operațiune de plată electronică sau efectuează orice acțiune printr-un canal la distanță care poate implica un risc de fraudă.

SCA este definită ca o procedură de autentificare bazată pe utilizarea a două sau mai multe elemente clasificate în categorii independente, astfel încât compromiterea unuia să nu compromită fiabilitatea celorlalte: (1) Cunoaștere – ceva

ce numai utilizatorul știe (parolă statică, cod PIN); (2) Posesie – ceva ce numai utilizatorul deține (token hardware, smartphone autorizat capabil să primească notificări push semnate criptografic); (3) Inerență – ceva ce utilizatorul este (caracteristici biometrice: amprentă digitală, recunoaștere facială, scanare de retină). În plus, pentru operațiunile de plată electronică la distanță, EBA RTS impune conceptul critic de legătură dinamică (Dynamic Linking): codul de autentificare generat trebuie să fie asociat matematic și univoc cu suma specifică a tranzacției și cu beneficiarul declarat de către plătitor. Dacă atacatorul încearcă să modifice beneficiarul sau suma în tranzit (atac de tip Man-in-the-Middle), codul de autentificare devine instantaneu nul.

### **1.1.2. Regulamentul DORA (Digital Operational Resilience Act - UE 2022/2554)**

Deși PSD2 a consolidat securitatea la nivelul canalului de inițiere a plăților, vulnerabilitățile la nivelul infrastructurilor de bază, dependențele critice față de furnizorii de servicii cloud și riscurile de întrerupere operațională au determinat legiuitorul european să adopte Regulamentul (UE) 2022/2554 privind reziliența operațională digitală a sectorului financiar (DORA). Aplicabil direct în toate statele membre începând cu data de 17 ianuarie 2025, DORA reprezintă o schimbare radicală de paradigmă: accentul este mutat de pe simpla conformitate pasivă (bifarea unor cerințe din liste de verificare) pe reziliența operațională activă, adică abilitatea unei entități financiare de a-și consolida, asigura și menține integritatea și continuitatea operațională în cazul unor întreruperi severe ale tehnologiilor informației și comunicațiilor (TIC).

Regulamentul DORA este structurat în jurul a cinci piloni operaționali obligatorii: (1) Cadrul de management al riscurilor TIC – consiliul de administrație al băncii poartă responsabilitatea directă pentru definirea politicilor de securitate, protecția activelor informatice, segmentarea rețelelor și implementarea de mecanisme automate de prevenire și detecție; (2) Clasificarea și raportarea incidentelor majore legate de TIC – băncile au obligația de a clasifica incidentele pe baza unor criterii cantitative și calitative stricte (clienți afectați, tranzacții blocate, impact geografic, exfiltrare de date) și de a transmite notificări inițiale către autoritățile naționale competente (pentru România, BNR și ASF) în termen de maximum 4 ore de la clasificare și nu mai târziu de 24 de ore de la detecția incidentului major; (3) Testarea periodică a rezilienței operaționale digitale – efectuarea anuală a unor teste riguroase de securitate și vulnerabilitate, iar pentru băncile de importanță sistemică, desfășurarea cel puțin o dată la trei ani a unor teste avansate de penetrare ghidate de amenințări reale (TLPT – Threat-Led Penetration Testing), bazate pe metodologia TIBER-EU; (4) Managementul riscurilor asociate furnizorilor terți de servicii TIC – stabilirea unui registru al tuturor acordurilor contractuale și supravegherea directă la nivel european a furnizorilor critici de servicii (furnizori de hyperscaler cloud, noduri SWIFT); (5) Acorduri de partajare a informațiilor – facilitarea schimbului legal de indicatori tehnici de compromitere (IoC – Indicators of Compromise) între instituțiile financiare pentru consolidarea apărării colective.

### **1.1.3. Standardul de Securitate a Datelor din Industria Cardurilor (PCI-DSS v4.0)**

În domeniul plăților electronice cu carduri bancare (de debit sau de credit), standardul internațional de referință este Payment Card Industry Data Security Standard (PCI-DSS), administrat de către Consiliul pentru Standarde de Securitate PCI (constituit de American Express, Discover, JCB, MasterCard și Visa). Lansată în versiunea 4.0 (cu aplicabilitate obligatorie deplină din martie 2025), noua specificație aduce modificări majore axate pe flexibilitatea controalelor de securitate, combaterea fraudelor de tip e-skimming și cerințe sporite de autentificare și criptografie.

Obiectivul fundamental al PCI-DSS este protecția Mediului de Date al Titularului de Card (CDE – Cardholder Data Environment), definit ca aria din rețeaua băncii care stochează, procesează sau transmite date despre carduri (Numărul Primar de Cont – PAN, Numele Titularului, Data Expirării) sau Date Sensibile de Autentificare (SAD – codul CVV2/CVC2, datele complete de pe banda magnetică, codurile PIN). Un principiu cheie al PCI-DSS este reducerea ariei de aplicare a auditului (Scope Reduction): o bancă sau o poartă de plăți trebuie să izoleze strict CDE prin micro-segmentare de rețea, firewall-uri și criptografie avansată. De asemenea, standardul interzice cu desăvârșire stocarea codului CVV după finalizarea autorizării și obligă la mascarea numărului de card în toate ecranele de afișare și jurnalele de sistem, permițând vizualizarea doar a primelor șase cifre (care identifică emitentul – BIN) și a ultimelor patru cifre.

### **1.1.4. Standardul ISO 20022 și Reglementările Băncii Naționale a României (BNR)**

Pe planul comunicațiilor interbancare și al decontărilor de mare valoare, asistăm la o revoluție tehnologică marcată de migrarea globală către standardul internațional ISO 20022. Timp de decenii, societatea interbancară SWIFT (Society for Worldwide Interbank Financial Telecommunication) a utilizat formate de mesagerie telegrafică nestructurată de tip MT (cum ar fi MT103 pentru transferuri de credit simple sau MT940 pentru extrase de cont). Aceste mesaje aveau limite severe de spațiu, caractere nestructurate și generau o rată ridicată de alerte false în sistemele de filtrare a sancțiunilor internaționale și de combatere a spălării banilor (AML).

Standardul ISO 20022 introduce o sintaxă structurată bazată pe scheme XML (eXtensible Markup Language) și codificări unificate de tip MX (de exemplu, pacs.008 pentru plăți de credit interbancare, pacs.002 pentru rapoarte de stare a plăților și camt.053 pentru extrase bancare). Fiecare tranzacție financiară este obligată să conțină un identificator unic universal de la un capăt la altul (UETR – Unique End-to-end Transaction Reference), generat ca un șir de caractere conform formatului RFC 4122 UUID Versiunea 4. Acest identificator permite urmărirea în timp real a fondurilor pe tot parcursul lanțului de corespondenți bancari prin serviciul SWIFT GPI (Global Payments Innovation).

La nivel național, Banca Națională a României (BNR) exercită atribuțiile de

supraveghere prudentială și monitorizare a infrastructurilor pieței financiare. Prin Regulamentul BNR nr. 4/2021 și normele conexe, banca centrală impune instituțiilor de credit autohtone cerințe riguroase de auditare periodică a securității sistemelor informatice, mecanisme obligatorii de redundanță pentru procesarea plăților prin sistemele ReGIS (decontare brută în timp real) și SENT (casa de compensare automată), precum și monitorizarea permanentă a conformității cu standardele europene.

**Tabelul 1.1: Sinteza cerințelor de conformitate și a sancțiunilor în sectorul financiar-bancar european**

| <b>Cadru /<br/>Directivă</b>         | <b>Emitent /<br/>Autoritate</b>            | <b>Obiectiv<br/>Principal de<br/>Securitate</b>                                                | <b>Sanctiuni<br/>Financiare /<br/>Impact</b>                                                             |
|--------------------------------------|--------------------------------------------|------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| PSD2 (Directiva<br>UE 2015/2366)     | Parlamentul<br>European / EBA              | SCA obligatoriu,<br>Open Banking<br>prin API,<br>Legătură<br>dinamică<br>sumă/beneficiar       | Până la 5% din<br>cifra de afaceri<br>anuală sau<br>retragerea<br>autorizației de<br>plată               |
| DORA<br>(Regulament UE<br>2022/2554) | Uniunea<br>Europeană<br>(direct aplicabil) | Reziliență<br>operațională TIC,<br>raportare<br>incidente majore<br>(<4h), teste<br>TLPT/TIBER | Amenzi de până<br>la 10 milioane<br>EUR sau 5% din<br>cifra de afaceri<br>mondială totală                |
| PCI-DSS v4.0                         | PCI Security<br>Standards<br>Council       | Izolarea CDE,<br>interzicerea<br>stocării CVV,<br>mascarea PAN,<br>criptarea<br>tranzacțiilor  | Amenzi de la<br>5.000 la 100.000<br>USD/lună din<br>partea rețelilor<br>Visa/Mastercard<br>și revocare   |
| ISO 20022 / BNR<br>Reg. 4/2021       | ISO / Banca<br>Națională a<br>României     | Mesagerie<br>financiară XML<br>structurată,<br>trasabilitate<br>UETR, audit<br>infrastructuri  | Sanctiuni<br>administrative,<br>suspendarea<br>participării la<br>sistemul de<br>decontare<br>ReGIS/SENT |

*Sursa: Sintează a autorului pe baza directivelor UE și a standardelor internaționale*

## **1.2. Arhitectura sistemelor informatice financiar-bancare**

Arhitectura software și hardware a unei bănci moderne este una dintre cele mai complexe structuri ingineresti din lumea digitală. Spre deosebire de aplicațiile

web comerciale generale, unde o eventuală eroare de sincronizare a datelor poate fi remediată printr-o reîncărcare de pagină, în sistemele bancare fiecare octet reprezintă active financiare reale. O singură tranzacție coruptă sau o neconcordanță între soldurile conturilor poate produce prejudicii ireparabile și poate atrage investigații prudențiale severe.

### 1.2.1. Sistemele de Core-Banking și Registrul General în Partidă Dublă

În centrul oricărei bănci se află sistemul de Core-Banking (Sistemul Central Bancar), reprezentat de platforme specializate precum Temenos Transact, SAP for Banking, Finacle, sau inițiative open-source de anvergură globală precum Apache Fineract și Mifos X (utilizate masiv în instituții financiare și organizații de micro-finanțare din întreaga lume). Misiunea fundamentală a motorului de Core-Banking este gestiunea stării conturilor, a clienților și, cel mai important, a Registrului General Contabil (General Ledger – GL).

Principiul imuabil care guvernează funcționarea registrului contabil încă din secolul al XV-lea (formalizat de Luca Pacioli) este contabilitatea în partidă dublă (Double-Entry Bookkeeping). Conform acestui model matematic, nicio sumă de bani nu poate apărea sau dispărea în mod spontan din sistem. Fiecare tranzacție financiară este compusă din cel puțin două înregistrări contabile contrare și perfect egale valoric: un debit și un credit. Relația de echilibru fundamental este exprimată prin ecuația matematică:

$$\sum_{i=1}^n \text{Debite}_i = \sum_{j=1}^m \text{Credite}_j$$

Din punct de vedere al bazei de date, sistemul de Core-Banking trebuie să garanteze proprietățile ACID (Atomicitate, Consistență, Izolare, Durabilitate). Atomicitatea garantează că transferul de fonduri de la contul A la contul B reprezintă o unitate indivizibilă: fie ambele conturi sunt actualizate și ambele linii din registru sunt inserate, fie nicio modificare nu persistă în baza de date în cazul unei erori la nivel de nod. Consistența garantează că sistemul trece doar dintr-o stare validă în altă stare validă, respectând toate constrângerile de integritate (de exemplu, interzicerea soldurilor negative dacă nu există o facilitare expresă de descoperit de cont – overdraft). Izolarea împiedică apariția fenomenelor de tip „dirty read” sau „race condition” la tranzacționări paralele concurente, iar Durabilitatea garantează persistența tranzacției pe suport nevolatil chiar și în caz de cădere totală de tensiune a serverului.

**Tabelul 1.2: Structura conturilor și corespondența partidei duble în sistemele Core-Banking**

| Tip Cont                 | Clasă Contabilă | Comportament la Debit | Comportament la Credit | Exemplu în Arhitectura Bancară                          |
|--------------------------|-----------------|-----------------------|------------------------|---------------------------------------------------------|
| Activ<br>(Assets)        | Clasa 1/2       | Crește soldul (+)     | Scade soldul (-)       | Rezervele băncii la banca centrală, Credite acordate    |
| Pasiv<br>(Liabilities)   | Clasa 3/5       | Scade soldul (-)      | Crește soldul (+)      | Depozitele clienților, Conturile curente ale populației |
| Cheltuieli<br>(Expenses) | Clasa 6         | Crește soldul (+)     | Scade soldul (-)       | Dobânzi plătite deponenților, Comisioane interbancare   |
| Venituri<br>(Revenues)   | Clasa 7         | Scade soldul (-)      | Crește soldul (+)      | Comisioane de procesare încasate, Dobânzi din credite   |

*Sursa: Sinteza autorului pe baza normelor de contabilitate bancară IFRS și standardelor Core-Banking*

### 1.2.2. Porțile de Plată Electronice (Payment Gateways) și Procesarea Tranzacțiilor

Dacă sistemul de Core-Banking reprezintă registrul intern de încredere, Poarta de Plăți (Payment Gateway) reprezintă interfața externă de acceptare a tranzacțiilor prin carduri bancare. Arhitectura tipică a procesării cardurilor implică cinci entități distincte: Titularul cardului (Cardholder), Comerciantul (Merchant), Banca Acceptatoare (Acquirer – banca la care comerciantul are contul deschis), Rețeaua de Carduri (Card Scheme / Card Brand – Visa sau Mastercard) și Banca Emitentă (Issuer – banca la care deținătorul cardului are contul și care a emis instrumentul de plată).

Ciclul de viață al unei tranzacții parcurge două faze distincte: (1) Autorizarea – verificarea în timp real a disponibilității fondurilor, a stării cardului și a absenței indicatorilor de fraudă; (2) Compensarea și Decontarea (Clearing & Settlement) – faza asincronă, derulată de obicei la sfârșitul zilei bancare (End-of-Day Batch), prin care fondurile sunt transferate efectiv între banca emitentă și cea acceptatoare prin conturile de decontare ale băncii centrale.

La nivel de validare matematică inițială pe poarta de plăți, orice număr primar de cont (PAN) trebuie să respecte algoritmul Luhn (cunoscut și sub denumirea de algoritmul Modulus 10), patentat de cercetătorul Hans Peter Luhn de la IBM în anul 1954. Acest algoritm calculează o cifră de control pentru a detecta erorile de tastare sau numerele de card sintetice generate aleatoriu. Formula matematică verifică dacă:

$$\left( \sum_{i=1}^n f(c_i) \right) \bmod{10} = 0$$

unde cifra de pe pozițiile pare numărate de la dreapta la stânga este dublată (dacă rezultatul depășește 9, se scade 9), iar cifrele de pe pozițiile impare se adună direct. Validarea algoritmului Luhn este primul filtru defensiv implementat în poarta de plată înainte de transmiterea oricărei cereri către procesatorul de carduri.

### 1.2.3. Comunicațiile Interbancare și Rețeaua SWIFT

Pentru transferurile transfrontaliere și transferurile de mare valoare dintre instituții de credit diferite, canalul standardizat de comunicație este rețeaua SWIFT. Infrastructura SWIFT operează ca un serviciu de mesagerie extrem de securizat, utilizând o rețea privată de date bazată pe protocoale criptografice dedicate (SWIFT Secure IP Network – SIPN). Fiecare instituție financiară conectată deține un Cod de Identificare a Afacerii (BIC – Business Identifier Code, conform ISO 9362), cunoscut public sub denumirea de cod SWIFT.

O componentă critică de securitate în cadrul nodului de conectare la rețeaua SWIFT (SWIFT Alliance Access sau Alliance Gateway) este asigurarea non-repudierii și a integrității mesajului prin intermediul infrastructurii cu chei publice (PKI). Fiecare mesaj financiar (fie el MT103 clasic sau pacs.008 XML) este semnat digital la nivelul modulului hardware de securitate (HSM – Hardware Security Module). În noul standard ISO 20022, mesajul este încapsulat într-un antet de aplicație (Business Application Header – BAH / ‘head.001’), care conține semnătura digitală a expeditorului și identificatorul unic universal de tranzacție UETR, împiedicând orice încercare de interceptare sau manipulare a fondurilor în tranzit.

## 1.3. Vectori de atac contemporani și analiza amenințărilor în sectorul bancar

Raportul ENISA Threat Landscape for the Financial Sector arată că industria bancară este ținta predilectă a celor mai sofisticăți atacatori cibernetici din lume. În timp ce atacatorii oportuniști caută să obțină câștiguri rapide prin scheme de inginerie socială direcționate împotriva clienților (phishing, smishing), grupările de criminalitate organizată de elită (cum ar fi Carbanak/FIN7, Lazarus Group, Evil Corp sau Silence) vizează direct infrastructura internă a instituțiilor financiare, urmărind manipularea registrelor, compromiterea fluxurilor de plăți sau paralizarea activității prin atacuri de tip ransomware.

### 1.3.1. Manipularea Bazelor de Date și Atacurile de tip SQL Injection

Baza de date este cel mai valoros activ informațional al unei bănci. Unul dintre cele mai devastatoare scenarii de atac constă în exploatarea unei vulnerabilități de tip SQL Injection (SQLi) la nivelul unei aplicații conexe (cum ar fi un portal de servicii clienți, o interfață de casierie sau un terminal de tip Kiosk neizolat corespunzător). Prin injectarea unor caractere de control și a unor instrucțiuni SQL malițioase (de exemplu, '1 OR '1'='1' sau 'UNION SELECT'), atacatorul poate eluda logica de autentificare a aplicației.

În mod și mai grav, dacă aplicația comunică cu baza de date utilizând un utilizator cu privilegii excesive (încalcând principiul privilegiului minim), atacatorul poate rula instrucțiuni de modificare a datelor ('UPDATE accounts SET balance = balance + 1000000.00 WHERE account\_id = '...'). Acest tip de fraudă, cunoscut sub denumirea de Balance Tampering (Manipularea Soldului), este deosebit de periculos deoarece generează monedă scripturală fictivă direct în baza de date fără a exista un flux corespondent de intrare de capital. Dacă sistemul nu deține un mecanism autonom de audit care să compare soldurile sintetice cu istoricul tranzacțiilor din ledger, atacatorul poate retrage fondurile create fraudulos prin rețeaua de bancomate sau prin transferuri internaționale înainte ca fraudă să fie descoperită la reconcilierea contabilă de sfârșit de lună.

### **1.3.2. Fraudele Tranzacționale: Card Stuffing, Velocity Floods și Credential Stuffing**

Porțile de plată electronice sunt permanent asaltate de rețele de calculatoare compromise (botnet-uri) care derulează atacuri automatizate de tip Card Stuffing (numit și Card Testing). În acest scenariu, atacatorii obțin baze de date ilicite din piețele underground (Darknet) conținând mii de numere de card parțial compromise (adesea fără CVV sau fără data de expirare validă). Utilizând boți paraleli de mare viteză, atacatorii transmit sute de cereri de plată de valoare minimă (de exemplu, 1 RON sau 0.50 EUR) către o poartă de plăți pentru a ghici combinația validă de CVV și dată de expirare prin forță brută.

Pe lângă riscul de compromitere a cardurilor legitime, astfel de atacuri de viteză (Velocity Floods) pot conduce la degradarea severă a performanței porții de plăți (Denial of Service), pot atrage amenzi usturătoare din partea schemelor de carduri Visa/Mastercard pentru rate anormale de autorizări eșuate și pot epuiza resursele hardware ale bazei de date financiare.

### **1.3.3. Mișcarea Laterală, Compromiterea Nodurilor Administrative și Infostealers**

Atacurile cibernetice moderne împotriva băncilor rareori reușesc să penetreze direct nucleul de Core-Banking dintr-o singură etapă. Modelul tipic de atac (descriș în matricea MITRE ATT&CK) debutează cu compromiterea unei stații de lucru obișnuite a unui angajat din rețeaua de birou (Office Network), fie printr-un email de tip spear-phishing cu atașament malițios, fie prin infectarea cu un troian de tip Infostealer (cum ar fi RedLine, Lumma Stealer sau Vidar).

Infostealer-ul exfiltrează din browser-ul angajatului cookie-urile de sesiune,

parolele salvate și fișierele cu chei private SSH. Odată obținut un cap de pod în rețea (Initial Access), atacatorul inițiază etapa de Mișcare Laterală (Lateral Movement). Dacă rețeaua băncii este plană sau insuficient segmentată, atacatorul va scana segmentele interne căutând protocoale de administrare la distanță (SSH, RDP, WinRM) pentru a sări de pe stația de lucru compromisă pe serverele de producție. Din acest motiv, lipsa unui punct unic, strict controlat și întărit de tranzit administrativ (Bastion Host / Jump-Box) reprezintă una dintre cele mai grave erori de arhitectură de securitate.

#### 1.3.4. Alterarea Mesageriei Financiare și Campaniile Ransomware cu Dublă Extorcare

Un alt vector avansat de atac îl constituie manipularea software-ului de middleware responsabil de procesarea fișierelor de tranzacții interbancare. Cel mai elocvent exemplu istoric îl reprezintă jaful cibernetic de 81 de milioane de dolari comis împotriva Băncii Centrale din Bangladesh în anul 2016 de către gruparea Lazarus. Atacatorii au pătruns în rețeaua internă, au instalat malware pe serverul de conectare SWIFT Alliance Access și au modificat dinamic fișierele de confirmare a plăților transmise către imprimantele de audit, mascând transferurile frauduloase către bănci din Filipine.

În paralel, amenințarea atacurilor de tip Ransomware a evoluat către modelul de Dublă și Triplă Extorcare (Double/Triple Extortion). Grupările de criminalitate cibernetică nu se limitează doar la criptarea bazelor de date financiare pentru a paraliza activitatea băncii, ci extrag în prealabil volume masive de date cu caracter personal ale clienților și detalii despre tranzacții, amenințând cu publicarea acestora pe site-uri de tip „name-and-shame” dacă nu este plătită o răscumpărare în criptomonede, expunând banca la amenzi colosale pe linia GDPR și DORA.

**Tabelul 1.3: Taxonomia principalilor vectori de atac bancari și impactul operațional asociat**

| Vector de Atac          | Tehnică<br>MITRE<br>ATT&CK                 | Mecanism de<br>Exploatare                                                | Impact<br>Potențial<br>Asupra Băncii                                            |
|-------------------------|--------------------------------------------|--------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| SQL Injection<br>(SQLi) | T1190 (Exploit<br>Public-Facing<br>App)    | Injectare comenzi<br>SQL în câmpuri<br>nefiltrate pentru<br>bypass auth  | Exfiltrare date<br>clienți, escaladare<br>de privilegii<br>administrative       |
| Balance<br>Tampering    | T1565.001<br>(Stored Data<br>Manipulation) | UPDATE direct<br>al tabeli<br>accounts fără<br>înregistrare în<br>ledger | Generare de<br>monedă<br>scripturală fictivă,<br>dezechilibru<br>contabil major |

| Vector de Atac          | Tehnică MITRE ATT&CK                      | Mecanism de Exploatare                                       | Impact Potențial Asupra Băncii                                           |
|-------------------------|-------------------------------------------|--------------------------------------------------------------|--------------------------------------------------------------------------|
| Card Stuffing / Testing | T1110.001 (Password/Data Guessing)        | Rafale automatizate de autorizări card cu CVV/dată aleatorii | Compromiterea cardurilor clienților, amenzi Visa/Mastercard, DoS         |
| Mișcare Laterală        | T1021.004 (Remote Services: SSH/RDP)      | Scanare rețea internă și conectare cu credențiale furate     | Compromiterea zonei de producție Core-Banking din segmentul Office       |
| SWIFT Heist / Corupere  | T1565.002 (Transmitted Data Manipulation) | Falsificarea fișierelor de tranzacții MT103/pacs.008 și UETR | Deturnare de fonduri internaționale de mare valoare, daune reputaționale |

*Sursa: Sinteză a autorului pe baza cadrului MITRE ATT&CK for Financial Services*

#### 1.4. Principii și mecanisme de securitate defensivă bancară

În fața amenințărilor asimetrice descrise anterior, instituțiile de credit trebuie să abandoneze definitiv vechea paradigmă defensivă a „castelului cu șanț de apă” (perimetru exterior puternic și încredere totală în interior) și să adopte o abordare integrată de Apărare în Adâncime (Defense-in-Depth) guvernată de arhitectura Zero Trust.

##### 1.4.1. Paradigma Zero Trust (ZTA) și Principiul Privilegiului Minim (PoLP)

Formalizată de Institutul Național de Standarde și Tehnologie din SUA prin publicația specială NIST SP 800-207, Arhitectura Zero Trust (Zero Trust Architecture – ZTA) pornește de la premisa fundamentală: „Nu avea niciodată încredere, verifică întotdeauna” (Never trust, always verify). Într-o arhitectură Zero Trust, nicio entitate – fie că este vorba despre un utilizator uman, o aplicație sau un server – nu primește încredere implicită pe baza poziției sale fizice sau a adresei IP din rețea.

Principiul Privilegiului Minim (Principle of Least Privilege – PoLP) impune ca fiecare modul software și fiecare operator bancar să aibă acces exclusiv la datele și resursele strict necesare pentru îndeplinirea atribuțiilor de serviciu. În contextul bazelor de date bancare, acest lucru presupune că serverul web de Core-Banking nu trebuie să dețină drepturi de administrare de tip ‘superuser’

sau ‘DROP/ALTER TABLE’ asupra bazei de date relaționale, ci doar permisiuni de execuție a procedurilor stocate strict necesare.

#### **1.4.2. Segmentarea Rețelei, VLAN-uri și Firewalling Stateful cu Inspecție Profundă**

Segmentarea de rețea constituie prima linie de apărare împotriva mișcării laterale a atacatorilor. Prin împărțirea infrastructurii fizice în Rețele Locale Virtuale distincte (VLAN-uri conforme standardului IEEE 802.1Q), traficul de rețea este complet izolat la nivelul stratului 2 OSI (Data Link Layer).

Trecerea oricărui pachet de date între două VLAN-uri se poate realiza exclusiv la nivelul stratului 3 OSI prin intermediul unui firewall stateful dedicat (cum ar fi OPNsense sau pfSense). O politică de securitate bancară robustă impune principiul Implicit Deny (Default Deny): orice trafic de rețea care nu este autorizat explicit printr-o regulă firewall prealabilă este automat blocat și jurnalizat. În plus, nodurile de procesare financiare nu trebuie niciodată expuse direct către Internet, fiind plasate în zone izolate din spatele unor zone demilitarizate (DMZ).

#### **1.4.3. Monitorizarea Integrității Datelor și Sistemele HIDS/SIEM (Wazuh)**

Prevenția nu este niciodată 100% eficientă; de aceea, capacitatea de detecție rapidă a anomaliilor este esențială. Sistemele de Management al Informațiilor și Evenimentelor de Securitate (SIEM – Security Information and Event Management), combinate cu Sisteme de Detecție a Intruziunilor la Nivel de Gazdă (HIDS – Host-based Intrusion Detection Systems), reprezintă „turnul de control” al securității unei bănci.

Platforma deschisă Wazuh reprezintă soluția lider de piață pentru monitorizarea unificată a infrastructurilor virtualizate. Agenții Wazuh instalați pe serverele bancare analizează în timp real jurnalele de sistem (Syslog, jurnalele bazei de date PostgreSQL, jurnalele de acces Nginx/FastAPI), monitorizează integritatea fișierelor de configurare critice (File Integrity Monitoring – FIM) și execută scripturi de auditare a integrității financiare. Prin decodificatoare și reguli de corelare personalizate, sistemul SIEM poate asocia o interogare suspectă din baza de date cu o tentativă de autentificare pe SSH, declanșând alerte automate de nivel critic către echipa de Centru de Operațiuni de Securitate (SOC – Security Operations Center).

#### **1.4.4. Bastioane Administrative (Jump-Box) cu Autentificare Ed25519 și MFA**

Pentru a proteja nodurile productive de accesul neautorizat al administratorilor de sistem sau al inginerilor DevOps, standardele bancare impun utilizarea unui Bastion Host (cunoscut și sub denumirea de Jump-Box sau Jump-Server). Jump-Box-ul este singurul nod din rețea căruia îi este permisă inițierea de conexiuni administrative (pe portul 22 SSH) către serverele interne de Core-Banking și baze de date.

Un Jump-Box conform normelor de securitate avansate elimină complet autentificarea bazată pe parole convenționale (vulnerabile la atacuri de dicționar, forță brută sau infostealers), impunând autentificarea asimetrică bazată pe criptografie pe curbe eliptice, utilizând algoritmul Ed25519 (Edwards-curve Digital Signature Algorithm). Ed25519 oferă un nivel de securitate echivalent cu RSA-3072, dar cu o lungime a cheii de doar 256 de biți, performanțe computaționale excepționale și imunitate demonstrată matematic la atacurile de tip „timing side-channel”. În completare, accesul pe Jump-Box este condiționat obligatoriu de un al doilea factor de autentificare de tip TOTP (Time-based One-Time Password, conform RFC 6238), generat pe un dispozitiv fizic independent.

**Tabelul 1.4: Comparație între arhitectura defensivă perimetrică tradițională și arhitectura Zero Trust**

| <b>Criteriu de Comparație</b> | <b>Abordare Tradițională (Perimetrică)</b>                        | <b>Abordare Zero Trust (Modernă Bancară)</b>                               |
|-------------------------------|-------------------------------------------------------------------|----------------------------------------------------------------------------|
| Model de Încredere            | Încredere implicită în tot ce se află în rețeaua internă (LAN)    | Încredere zero; fiecare pachet și identitate sunt verificate continuu      |
| Segmentare Rețea              | Rețea plană sau împărțită doar grosier în LAN și DMZ              | Micro-segmentare granulară prin VLAN-uri dedicate (IEEE 802.1Q)            |
| Controlul Accesului           | Parole statice, drepturi largi acordate pe grupuri globale        | Autentificare MFA + chei asimetrice Ed25519, RBAC strict și PoLP           |
| Inspecția Traficului          | Filtrare doar la intrarea în rețea prin firewall exterior         | Inspecție stateful inter-VLAN cu politică Default-Deny și analiză SIEM     |
| Auditul Integrității          | Verificare manuală periodică a fișierelor și extraselor contabile | Audit continuu în timp real prin agenți HIDS/SIEM (Wazuh) și hash chaining |

*Sursa: Sinteză teoretică a autorului pe baza standardului NIST SP 800-207*

## **CAPITOLUL 2. PROIECTAREA, IMPLEMENTAREA ȘI EVALUAREA ARHITECTURII BANCARE REZILIENTE ÎNTR-UN MEDIU VIRTUALIZAT**

### **2.1. Arhitectura generală și topologia laboratorului virtual bancar**

Pentru a valida experimental conceptele teoretice și standardele de securitate analizate în primul capitol, a fost proiectat și instanțiat un mediu virtualizat

complet de laborator bancar. Obiectivul arhitectural central a fost reproducerea fidelă a unei infrastructuri bancare corporative moderne, asigurând izolarea strictă a subsistemelor critice, monitorizarea continuă a stării securității și capacitatea de a rezista la atacuri cibernetice sofisticate.

### 2.1.1. Platforma de Virtualizare Proxmox VE 9.2 și Dimensionarea Resurselor

Infrastructura de calcul a fost implementată pe platforma de virtualizare de nivel întreprindere Proxmox Virtual Environment (PVE) versiunea 9.2 (nucleu Linux 7.0 pve), instalată bare-metal pe nodul fizic x86\_64 primar al laboratorului (pve). Serverul este echipat cu un procesor Intel Core i3-10100F (4 nuclee fizice, 8 fire de execuție, frecvență de bază 3.60 GHz și până la 4.30 GHz Turbo, 6 MB Smart Cache), 12 GB de memorie RAM DDR4 la 2133 MHz (12.288 MB), o placă grafică dedicată NVIDIA GeForce GTX 1050 Ti (4 GB VRAM GDDR5), un subsistem de stocare de 512 GB SSD (gestionat printr-un pool LVM-Thin de mare viteză) și un modul ZRAM de 6.0 GB (/dev/zram0, compresie lz4, swappiness 60) ce garantează densitatea ridicată a sarcinilor de lucru și previne degradarea mediilor SSD prin VirtIO Memory Ballooning.

Platforma Proxmox VE oferă o combinație optimă între mașini virtuale complete bazate pe KVM (Kernel-based Virtual Machine) – utilizate pentru nodurile care necesită izolare strictă la nivel de nucleu al sistemului de operare – și containere ușoare bazate pe nucleu Linux (LXC – Linux Containers) – utilizate pentru microserviciile cu rată ridicată de tranzacționare și platforma SIEM Wazuh. Pentru eficientizarea consumului de memorie și garantarea disponibilității în perioadele de vârf tranzacțional, mașinile virtuale au fost configurate cu alocare dinamică de memorie (Memory Ballooning via virtio-balloon).

**Tabelul 2.1: Specificațiile tehnice și alocarea resurselor pentru activele virtualizate din nodul fizic Proxmox VE 9.2**

| ID Activ | Denumire Nod      | Tip Virtu-alizare | Sistem de Op-erare     | Alocare vCPU / RAM               | Stocare LVM | Rol Funcțional                                          |
|----------|-------------------|-------------------|------------------------|----------------------------------|-------------|---------------------------------------------------------|
| VM 200   | opnsense-firewall | KVM (pve)         | FreeBSD 14 / OP-Nsense | 2 vCPU / 1024 MB (512MB balloon) | 20 GB SSD   | Firewall de frontieră, gateway inter-VLAN, IDS Suricata |

| <b>ID<br/>Activ</b> | <b>Denumire<br/>Nod</b>         | <b>Tip<br/>Virtu-<br/>alizare</b> | <b>Sistem<br/>de Op-<br/>erare</b> | <b>Alocare<br/>vCPU<br/>/ RAM</b>             | <b>Stocare<br/>LVM</b> | <b>Rol<br/>Funcțional</b>                                                           |
|---------------------|---------------------------------|-----------------------------------|------------------------------------|-----------------------------------------------|------------------------|-------------------------------------------------------------------------------------|
| VM 310              | core-<br>banking-<br>licenta    | KVM<br>(pve)                      | Debian<br>12 Book-<br>worm         | 2 vCPU<br>/ 2048<br>MB<br>(1024MB<br>balloon) | 40 GB<br>SSD           | Motor<br>central<br>Core-<br>Banking,<br>ledger în<br>partidă<br>dublă<br>SHA-256   |
| VM 311              | fin-db-<br>licenta              | KVM<br>(pve)                      | Debian<br>12 Hard-<br>ened         | 2 vCPU<br>/ 2048<br>MB<br>(1024MB<br>balloon) | 50 GB<br>SSD           | Server<br>bază de<br>date fi-<br>nanciară<br>Post-<br>greSQL<br>+ recon-<br>ciliere |
| CT 312              | payment-<br>gateway-<br>licenta | LXC<br>(pve)                      | Alpine<br>Linux<br>3.19            | 1 vCPU<br>/ 1024<br>MB (fix)                  | 10 GB<br>rootfs        | Microserviciu<br>plăți<br>rapide<br>card<br>(Luhn)<br>& ISO<br>20022<br>pacs.008    |
| VM 313              | swift-<br>jumpbox-<br>licenta   | KVM<br>(pve)                      | Debian<br>12 Hard-<br>ened         | 2 vCPU<br>/ 1024<br>MB<br>(512MB<br>balloon)  | 25 GB<br>SSD           | Bastion<br>adminis-<br>trativ<br>unic,<br>SSH<br>Ed25519<br>+ MFA<br>TOTP           |
| CT 106              | wazuh-<br>siem-<br>licenta      | LXC<br>(pve)                      | Ubuntu<br>24.04<br>LTS             | 4 vCPU<br>/ 6144<br>MB<br>(4GB<br>Heap)       | 35 GB<br>rootfs        | Platformă<br>centrală<br>SIEM/XDR,<br>OpenSearch<br>Indexer<br>& Dash-<br>board     |

| ID<br>Activ | Denumire<br>Nod                | Tip<br>Virtu-<br>alizare | Sistem<br>de Op-<br>erare | Alocare<br>vCPU<br>/ RAM     | Stocare<br>LVM | Rol<br>Funcțional                                                           |
|-------------|--------------------------------|--------------------------|---------------------------|------------------------------|----------------|-----------------------------------------------------------------------------|
| VM 205      | kiosk-<br>terminal-<br>licenta | KVM<br>(pve)             | Ubuntu<br>24.04<br>LTS    | 2 vCPU<br>/ 1024<br>MB (fix) | 20 GB<br>SSD   | Terminal<br>tranzacțional<br>securizat<br>casierie/kiosk<br>(VLAN<br>20/30) |

*Sursa: Proiectare proprie a autorului în cadrul infrastructurii Proxmox VE*

### 2.1.2. Segmentarea Rețelei prin Firewall OPNsense și Politici Inter-VLAN

La nivelul stratului de conectivitate, hypervisorul Proxmox utilizează o punte de rețea virtuală compatibilă cu standardul IEEE 802.1Q ('vbr0'). Întreaga topologie de rețea este guvernată de o mașină virtuală dedicată rulând distribuția specializată OPNsense (VM 200), care acționează ca router și firewall stateful de mare viteză.

Infrastructura a fost divizată logic în trei Rețele Locale Virtuale (VLAN-uri) strict segregate, fiecareia fiindu-i asociată o clasă privată de adrese IPv4 și un rol de securitate bine definit:

- **VLAN 10 (Management / 192.168.10.0/24):** Zonă rezervată exclusiv traficului de administrare a infrastructurii. În această zonă este amplasat nodul bastion VM 313 (Jump-Box, IP 192.168.10.50). Niciun alt nod din bancă nu poate fi administrat direct fără a tranzita acest bastion.
- **VLAN 20 (Services / 192.168.20.0/24):** Zona de înaltă securitate a băncii (High-Security Financial Core). Aici sunt găzduite cele trei active financiare productive: serverul Core-Banking (VM 310, IP 192.168.20.50), serverul de baze de date (VM 311, IP 192.168.20.51) și poarta de plăți electronice (CT 312, IP 192.168.20.52). Această zonă este complet inaccesibilă direct din afara băncii.
- **VLAN 30 (CyberLab & DMZ / 192.168.30.0/24):** Zonă izolată destinată simulării atacurilor cibernetice și testării de penetrare. Aici este plasată mașina ofensivă Kali Linux (VM 302, IP 192.168.30.15), reprezentând o stație de lucru compromisă sau un atacator extern care a obținut acces în rețeaua secundară a organizației.

**Tabelul 2.2: Matricea de rutare și politicile de securitate firewalling OPNsense (VLAN 10, 20, 30)**

| <b>Zonă Sursă</b>              | <b>Zonă Destinație</b>      | <b>Port / Protocol</b>     | <b>Acțiune Firewall</b> | <b>Justificare Tehnico-Economică</b>                                             |
|--------------------------------|-----------------------------|----------------------------|-------------------------|----------------------------------------------------------------------------------|
| VLAN 10<br>(Bastion 313)       | VLAN 20<br>(VM 310, 311)    | TCP / 22<br>(SSH)          | ALLOW<br>(Log)          | Tranzit administrativ autorizat exclusiv prin chei criptografice Ed25519 și MFA  |
| VLAN 20<br>(VM 310 Core)       | VLAN 20<br>(VM 311 DB)      | TCP / 5432<br>(PostgreSQL) | ALLOW<br>(Inspect)      | Interogare internă a bazei de date financiare strict între serviciile autorizate |
| VLAN 20<br>(CT 312 Gateway)    | VLAN 20<br>(VM 310 Core)    | TCP / 8080<br>(REST API)   | ALLOW<br>(Inspect)      | Transmitere instrucțiuni de compensare plăți după validarea riscului             |
| VLAN 30<br>(CyberLab Attacker) | VLAN 20<br>(Financial Core) | ORICE<br>(ANY)             | BLOCK<br>(Drop & Alert) | Regulă Default-Deny: izolarea completă a zonei financiare de mediul neîncrezut   |
| VLAN 30<br>(CyberLab Attacker) | VLAN 10<br>(Bastion 313)    | TCP / 22<br>(SSH)          | ALLOW<br>(Inspect)      | Acces permis exclusiv la poarta de intrare SSH pentru verificarea MFA            |

*Sursa: Politici de securitate definite și implementate în OPNsense Firewall*

## 2.2. Implementarea componentelor bancare fundamentale

În concordanță cu obiectivele aplicative ale lucrării de licență, pe activele virtualizate din VLAN 20 și VLAN 10 a fost dezvoltată și integrată o suită completă de servicii software financiare scrise în limbajul Python 3, respectând arhitectura modulară și standardele industriei bancare.

### **2.2.1. Mașina Virtuală Core-Banking Engine (VM 310) și Ledger-ul Criptografic**

Nodul VM 310 ('192.168.20.50') găzduiește motorul de Core-Banking, conceput pe baza principiilor arhitecturale ale proiectului open-source Apache Fineract. Serviciul expune o interfață RESTful securizată dezvoltată pe baza cadrului FastAPI, rulată în producție prin intermediul serverului ASGI Uvicorn asistat de un proxy invers Nginx.

Punctul central al motorului este clasa 'CoreBankingEngine', care implementează registrul contabil în partidă dublă (General Ledger). La inițierea oricărui transfer de fonduri, motorul efectuează următoarele validări stricte: (1) Verificarea existenței și stării active a contului sursă și contului destinație; (2) Verificarea suficienței soldului disponibil pe contul sursă; (3) Validarea rolului utilizatorului (RBAC – doar utilizatorii cu rolul „teller” sau „admin” pot iniția operațiuni); (4) Validarea adresei IP de proveniență a cererii (doar adresele IP autorizate ale casierilor '192.168.20.10' sau ale terminalului de tip Kiosk '192.168.20.100' / '192.168.1.205' sunt acceptate).

Pentru a preveni atacurile din interior (Insider Threats) și tentativele de alterare retroactivă a istoricului tranzacțional, registrul contabil folosește un mecanism avansat de înlănțuire criptografică de tip tamper-evident bazat pe algoritmul de dispersie SHA-256. Fiecare înregistrare din registru conține o amprentă digitală unică ('record\_hash') calculată peste identificatorul tranzacției, contul sursă, contul destinație, suma transferată, moneda, timestamp-ul exact în format ISO 8601 și hash-ul înregistrării imediat precedente ('prev\_hash'). Oricare încercare a unui atacator sau administrator corupt de a modifica retroactiv o sumă sau un beneficiar rupe lanțul criptografic, starea de corupere fiind sesizată instantaneu de auditorul de securitate.

### **Listarea de cod: 2.1: Algoritmul de înlănțuire criptografică SHA-256 a registrului contabil în Core-Banking**

---

```

def _compute_hash(self, tx_id: str, src: str, dst: str, amount: float,
currency: str, timestamp: str, prev_hash: str) -> str:
"""Calcul amprentă SHA-256 pentru înlănțuirea criptografică a registrului."""
payload =
f"{tx_id}|{src}|{dst}|{amount:.2f}|{currency}|{timestamp}|{prev_hash}"
return hashlib.sha256(payload.encode("utf-8")).hexdigest()

# La inserarea tranzacției în General Ledger:
prev_hash = self.ledger[-1]["record_hash"] if self.ledger else "0" * 64
record_hash = self._compute_hash(tx_id, src_acc, dst_acc, amount,
currency, timestamp_iso, prev_hash)

```

---

*Sursa: Elaborare proprie a autorului în cadrul laboratorului de cercetare*

### 2.2.2. Mașina Virtuală Financial Database (VM 311) și Motorul de Audit Wazuh

Pe mașina virtuală VM 311 ('192.168.20.51') a fost implementat sistemul de gestiune a bazelor de date relaționale financiar-bancare, reflectând arhitectura unui server PostgreSQL de producție. Schema de date a fost concepută conform formelor normale (3NF) și include patru tabele relaționale de importanță critică:

- **Tabela clients:** Stochează identitatea verificată a clienților băncii conform procedurilor KYC (Know Your Customer): 'client\_id' (UUID), 'cnp\_hash' (stocare prin hash SHA-256 pentru protecția datelor cu caracter personal conform GDPR), 'full\_name', 'email', 'risk\_score' și 'status'.
- **Tabela accounts:** Găzduiește evidența sintetică a conturilor bancare: 'account\_id' (IBAN), 'client\_id' (cheie străină cu 'ON DELETE RESTRICT'), 'currency', 'balance' (numeric cu 2 zecimale, protejat de constrângerea 'CHECK (balance >= 0)'), 'account\_type' și 'is\_frozen'.
- **Tabela ledger\_transactions:** Registrul imuabil al tranzacțiilor: 'tx\_id', 'source\_account\_id', 'destination\_account\_id', 'amount', 'currency', 'timestamp', 'record\_hash' și 'prev\_hash'.
- **Tabela financial\_audit\_log:** Jurnalul securizat de audit: 'log\_id', 'event\_type', 'severity', 'details', 'timestamp' și 'ip\_source'.

**Tabelul 2.3: Structura schemei de date relaționale a serverului financiar (VM 311)**

| <b>Tabel<br/>Relațional</b> | <b>Coloane Cheie</b>                                           | <b>Constrângeri<br/>de Integritate</b>    | <b>Mecanism de<br/>Securitate<br/>Asociat</b>                                     |
|-----------------------------|----------------------------------------------------------------|-------------------------------------------|-----------------------------------------------------------------------------------|
| clients                     | client_id (PK),<br>cnp_hash,<br>full_name,<br>risk_score       | PRIMARY KEY,<br>UNIQUE<br>(cnp_hash)      | Pseudonimizare<br>GDPR prin<br>dispersie<br>criptografică<br>unidirecțională      |
| accounts                    | account_id (PK),<br>client_id (FK),<br>balance,<br>is_frozen   | FOREIGN KEY,<br>CHECK (balance<br>>= 0.0) | Blocare overdraft<br>neautorizat, flag<br>de înghețare<br>imediată a<br>activului |
| ledger_transactions         | tx_id (PK), src,<br>dst, amount,<br>record_hash,<br>prev_hash  | PRIMARY KEY,<br>CHECK (amount<br>> 0)     | Înlănțuire<br>criptografică<br>SHA-256<br>tamper-evident<br>(General Ledger)      |
| financial_audit_log         | log_id (PK),<br>event_type,<br>severity, details,<br>timestamp | PRIMARY KEY,<br>NOT NULL fields           | Jurnalizare<br>append-only<br>auditată în timp<br>real de agentul<br>Wazuh SIEM   |

*Sursa: Proiectarea schemei de baze de date conform normelor ACID*

O inovație esențială a acestei lucrări este modulul ‘WazuhSecurityAuditor’, dezvoltat pentru a audita în mod activ baza de date. Pe lângă inspectarea interogărilor SQL în căutarea unor semnături clasice de injectare (‘UNION SELECT’, ‘OR '1'='1’), auditorul implementează un mecanism periodic de reconciliere matematică: pentru fiecare cont bancar, auditorul calculează soldul istoric real prin însumarea tuturor debitelor și creditelor din tabela ‘ledger\_transactions’ și îl compară cu valoarea câmpului ‘balance’ din tabela ‘accounts’.

Dacă un atacator reușește să ruleze un ‘UPDATE accounts SET balance = ...’ direct în baza de date fără a avea o tranzacție justificativă aprobată în ledger, auditorul detectează discrepanța matematică, îngheață automat contul fraudat (‘is\_frozen = TRUE’) și emite instantaneu o alertă Wazuh de nivel critic 14 (Regula ID 100109 – Balance Tampering Detected).

**Listarea de cod: 2.2: Algoritmul de verificare automată a dezechili-  
brului contabil și declanșare a alertei Wazuh**

---

```

def verify_account_balance_integrity(self, account_id: str) -> Tuple[bool,
float, float]:
    """Verifică concordanța dintre soldul stocat și suma tranzacțiilor din ledger."""
    # 1. Extragere sold curent din accounts
    cur.execute("SELECT balance, initial_balance FROM accounts WHERE
account_id = ?", (account_id,))
    stored_balance, init_bal = cur.fetchone()

    # 2. Reconstrucție sold din tranzacțiile General Ledger (Credite - Debite)
    cur.execute("SELECT COALESCE(SUM(amount), 0) FROM
ledger_transactions WHERE dst = ?", (account_id,))
    total_credits = cur.fetchone()[0]
    cur.execute("SELECT COALESCE(SUM(amount), 0) FROM
ledger_transactions WHERE src = ?", (account_id,))
    total_debits = cur.fetchone()[0]

    computed_balance = init_bal + total_credits - total_debits
    if abs(stored_balance - computed_balance) > 0.001:
        self.emit_wazuh_alert(
            rule_id=100109, level=14,
            description="CRITICAL: Balance Tampering Detected via Discrepancy Audit",
            details=f"Stored: {stored_balance} | Computed: {computed_balance}"
        )
    return False, stored_balance, computed_balance
    return True, stored_balance, computed_balance

```

---

*Sursa: Elaborare proprie a autorului în cadrul laboratorului de cercetare*

### **2.2.3. Containerul LXC Payment Gateway & SWIFT Simulator (CT 312)**

Găzduit în containerul LXC CT 312 ('192.168.20.52'), microserviciul de poartă de plăți simulează atât acceptarea tranzacțiilor de comerț electronic cu carduri bancare (Visa / Mastercard), cât și generarea instrucțiunilor de decontare interbancară SWIFT.

Serviciul implementează un lanț robust de filtre defensive: (1) Validarea structurală prin algoritmul Luhn (Modulus 10); (2) Conformitatea PCI-DSS prin mascare imediată a PAN-ului ('card\_number[:6] + '\*' \* 6 + card\_number[-4:]') și distrugerea din memorie a codului CVV după procesare; (3) Analiza Riscului Tranzacțional conform normelor EBA/PSD2, impunând obligativitatea SCA pentru sume tranzacționate care depășesc pragul de 10.000 EUR; (4) Limitator de viteză pe bază de fereastră glisantă (Sliding Window Rate Limiter), care monitorizează frecvența tranzacțiilor per adresă IP și per număr de card, blocând tentativele de Card Stuffing ce depășesc 5 cereri pe minut cu codul HTTP 429 Too Many Requests.

Pentru fluxul de transferuri interbancare de mare valoare, modulul generează mesaje în format SWIFT MT103 și mesaje XML conforme schemei ISO 20022 ‘pacs.008.001.08’. Mesajele includ antetul de afaceri BAH (‘head.001’), codurile BIC ale băncii inițitoare și băncii receptoare, precum și identificatorul universal UETR generat ca UUID Versiunea 4 conform RFC 4122.

### Listarea de cod: 2.3: Validarea algoritmului Luhn și mascarea PAN pe poarta de plăți (CT 312)

---

```
def validate_luhn(card_number: str) -> bool:
    """Validare matematică a cifrei de control conform algoritmului Luhn (Mod
    10)."""
    cleaned = re.sub(r"\D", "", card_number)
    if not (13 <= len(cleaned) <= 19):
        return False
    digits = [int(d) for d in cleaned]
    odd_digits = digits[-1::-2]
    even_digits = digits[-2::-2]
    checksum = sum(odd_digits)
    for d in even_digits:
        checksum += sum(divmod(d * 2, 10))
    return checksum % 10 == 0

def mask_pan(card_number: str) -> str:
    """Mascarea numărului de card conform cerințelor stricte PCI-DSS v4.0."""
    digits = re.sub(r"\D", "", card_number)
    if len(digits) < 10:
        return "INVALID_PAN"
    return f"{digits[:6]}{'*' * (len(digits) - 10)}{digits[-4:]}"
```

---

*Sursa: Elaborare proprie a autorului în cadrul laboratorului de cercetare*

### 2.2.4. Mașina Virtuală SWIFT Jump-Box (VM 313) cu Securitate Sporită

Nodul VM 313 (‘192.168.10.50’), plasat în VLAN 10, constituie unicul punct de acces administrativ autorizat către serverele din VLAN 20. Configurația mașinii virtuale a fost supusă unui proces complet de întărire a securității (OS Hardening) la nivelul distribuției Debian 12 Minimal.

Parametrii serviciului OpenSSH (‘/etc/ssh/sshd\_config’) au fost restricționați drastic: (1) ‘PasswordAuthentication no’ – eliminarea completă a autentificării prin parole convenționale; (2) ‘PermitRootLogin no’ – interzicerea accesului direct pentru utilizatorul root; (3) ‘PubkeyAuthentication yes’ – impunerea exclusivă a cheilor criptografice asimetrice pe curbe eliptice Ed25519; (4) ‘AuthenticationMethods publickey,keyboard-interactive’ – combinarea obligatorie

a cheii private cu un token de autentificare în doi factori generat prin modulul ‘libpam-google-authenticator’ (TOTP); (5) Închiderea tuturor porturilor de ieșire la nivelul firewall-ului local ‘iptables/nftables’, cu excepția rutării pe portul 22 către adresele ‘192.168.20.50’ și ‘192.168.20.51’.

### 2.3. Scenarii experimentale de atac, simulare și validare defensivă

Pentru a valida în mod riguros capacitatea de reziliență cibernetică a infrastructurii proiectate, a fost elaborată o suită completă de simulare ofensivă și defensivă automatizată (‘banking\_attack\_simulator.py’). Suita rulează în mod programatic 5 scenarii de atac complexe, acoperind întregul spectru de amenințări analizate în Capitolul 1, mapate riguros pe tehnicile internaționale MITRE ATT&CK.

#### 2.3.1. Scenariul 1: Linia de Bază Tranzacțională Kiosk/Casierie (T1078)

Scenariul 1 are rolul de a stabili linia de bază de funcționare nominală (Baseline). Se simulează o zi bancară curentă, în care terminalul securizat de tip Kiosk (VM 205 / ‘192.168.20.100’) și un casier autorizat (‘192.168.20.10’) inițiază un transfer legitim de 250.00 EUR între contul clientului Popescu Ion (‘RO03BTRL000000000000000001’) și contul clientului Ionescu Maria (‘RO03BTRL000000000000000002’).

Sistemul validează autentificarea, verifică solvabilitatea plătitorului, actualizează simultan soldurile prin intermediul tranzacției ACID în PostgreSQL, calculează noul ‘record\_hash’ SHA-256 înălțuit pe baza hash-ului anterior și înregistrează operațiunea în ‘financial\_audit\_log’. Verificarea auditorului de integritate confirmă un dezechilibru zero între conturi și registru ( $\Delta = 0.00$ ), fiind generat un eveniment de audit de nivel de informare (Wazuh Rule 100101, Severity Level 3).

#### 2.3.2. Scenariul 2: Atac SQL Injection și Alterare de Sold - Balance Tampering (T1190/T1565)

În acest scenariu, atacatorul simulat (Red Team) încearcă inițial să exploateze interfața de căutare a clienților prin injectarea clasică a vectorului ‘‘ OR ‘1’=‘1’’. Modulul de securitate interceptează semnătura și blochează cererea. Ulterior, atacatorul simulează compromiterea conexiunii și execută o comandă SQL directă de tip ‘UPDATE accounts SET balance = 5000000.00 WHERE account\_id = ‘RO03BTRL000000000000000001’’, crescând artificial soldul cu 4.985.000 EUR.

La declanșarea ciclului de auditare, ‘WazuhSecurityAuditor’ efectuează reconcilierea matematică între tabela ‘accounts’ și tabela ‘ledger\_transactions’. Deoarece nu există nicio tranzacție justificativă în ledger pentru suma de 5 milioane EUR, auditorul detectează discrepanța critică. Contul este înghețat instantaneu (‘is\_frozen = TRUE’), tranzacțiile de retragere sunt refuzate, și este emisă alerta Wazuh Rule ID 100109 de severitate maximă (Level 14 – Critical Balance Tampering). Frauda este anihilată înainte de a se produce vreo pierdere patrimonială reală.

### **2.3.3. Scenariul 3: Atac de tip Card Stuffing și Velocity Flood pe Poarta de Plăți (T1110)**

Scenariul 3 simulează un botnet ofensiv care trimite o rafală de 20 de cereri de autorizare de plăți cu sume mici (1.50 EUR) într-un interval de sub 3 secunde, utilizând numere de card sintetice și încercări succesive de ghicire a codului CVV. Primele cereri cu carduri invalide sunt respinse pe loc de algoritmul Luhn fără a încărca baza de date.

La atingerea pragului de 5 cereri pe minut per adresă IP/card, mecanismul de Velocity Check intervine prompt, activând blocarea automată cu codul de răspuns HTTP 429 (Too Many Requests). Sistemul emite alerta de securitate Wazuh Rule 100103 (Rate Limit Threshold Exceeded), protejând infrastructura băncii împotriva indisponibilității de tip DoS și respectând cerințele de prudență impuse de rețelele internaționale de carduri.

### **2.3.4. Scenariul 4: Tentativă de Mișcare Laterală și Eludare Jump-Box (T1021)**

În cadrul acestui scenariu, atacatorul aflat pe nodul ofensiv Kali Linux din VLAN 30 ('192.168.30.15') simulează obținerea accesului pe o stație de lucru din rețeaua internă. Atacatorul scanează gama de adrese și încearcă să stabilească conexiuni directe SSH pe portul 22 către VM 310 ('192.168.20.50') și conexiuni PostgreSQL pe portul 5432 către VM 311 ('192.168.20.51').

Pachetele TCP SYN sunt interceptate și aruncate (DROP) instantaneu la nivelul firewall-ului OPNsense în virtutea politicii stricte Default-Deny inter-VLAN. Atacatorul încearcă apoi conectarea pe unicul port vizibil – portul 22 al Jump-Box-ului (VM 313) din VLAN 10 – utilizând un atac de dicționar de parole. Deoarece serviciul SSH are autentificarea prin parole complet dezactivată și solicită cheie privată Ed25519 validată de un token MFA, conexiunea este respinsă imediat cu mesajul 'Permission denied (publickey,keyboard-interactive)'. Tentativa este jurnalizată ca alertă de forță brută (Wazuh Rule 100105).

### **2.3.5. Scenariul 5: Falsificarea Mesageriei SWIFT și Coruperea UETR (T1565)**

Ultimul scenariu vizează un atac avansat de manipulare în tranzit a unui mesaj financiar interbancar ISO 20022 'pacs.008'. Atacatorul interceptează fluxul și introduce un mesaj fraudulos cu un identificator UETR alterat (un șir de caractere static corupt în locul unui UUID v4 RFC 4122) și o sumă modificată neautorizat.

La primire, validatorul structural al porții de plăți analizează schema XML și atributele de non-repudiare din Business Application Header ('head.001'). Detectorul identifică invaliditatea structurală a UETR-ului și neconcordanța hash-ului tranzacției, refuză introducerea mesajului în coada de decontare și declanșează alerta Wazuh Rule 100106 (Corrupted Interbank SWIFT Message / Invalid UETR).

**Tabelul 2.4: Rezultatele testării experimentale pentru cele 5 scenarii de atac (Red Team vs. Blue Team)**

| Cod Scenariu | Vector de Atac Simulat                   | Mecanism Defensiv Testat                        | Indicator de Detecție Wazuh                    | Rezultat Testare          |
|--------------|------------------------------------------|-------------------------------------------------|------------------------------------------------|---------------------------|
| SCENARIO-01  | Tranzacționare nominală casierie (T1078) | ACID DB, dublă înregistrare, SHA-256 Ledger     | Wazuh Rule 100101 (Level 3 - Informațional)    | 100% SUCCES (Nominal)     |
| SCENARIO-02  | SQLi & Balance Tampering (T1190/T1565)   | Filtrare parametri, reconciliere automată sold  | Wazuh Rule 100109 (Level 14 - Critic Alert)    | 100% SUCCES (Blocat)      |
| SCENARIO-03  | Card Stuffing & Velocity Flood (T1110)   | Algoritm Luhn, Sliding Window Rate Limiter      | Wazuh Rule 100103 (Level 10 - High Rate Limit) | 100% SUCCES (Blocat 429)  |
| SCENARIO-04  | Mișcare laterală din DMZ (T1021)         | Firewall OPNsense Default-Deny, SSH Ed25519+MFA | Wazuh Rule 100105 (Level 12 - Bastion Drop)    | 100% SUCCES (Blocat Drop) |
| SCENARIO-05  | Falsificare mesaj SWIFT/UETR (T1565)     | Validare schemă ISO 20022 pacs.008, regex UETR  | Wazuh Rule 100106 (Level 12 - Corrupted UETR)  | 100% SUCCES (Respins)     |

*Sursa: Rezultate generate direct din execuția suitei `banking_attack_simulator.py`*

#### **2.4. Monitorizarea securității, colectarea telemetriei și corelarea evenimentelor în Wazuh SIEM**

Capacitatea de reacție a Centrului de Operațiuni de Securitate (SOC) depinde direct de calitatea telemetriei colectate. În laboratorul bancar, agentul Wazuh a fost configurat să preia evenimentele emise pe canalele Syslog și JSON ale componentelor bancare, utilizând decodificatoare personalizate (Custom Decoders) și un set dedicat de reguli de corelare în format XML.

Fiecare regulă Wazuh definește o condiție logică de potrivire, un nivel de severitate (de la 1 la 16 conform clasificării OSSEC/Wazuh) și o mapare directă pe matricea MITRE ATT&CK. Spre deosebire de sistemele convenționale care

alertează doar la eșecul autentificării, arhitectura implementată corelează evenimentele de infrastructură cu evenimentele de afaceri financiare.

**Tabelul 2.5: Maparea alertelor de securitate pe matricea MITRE ATT&CK for Financial Services**

| <b>Regulă<br/>Wazuh ID</b> | <b>Nivel<br/>Severitate</b> | <b>Tehnică<br/>MITRE<br/>ATT&amp;CK</b> | <b>Descriere<br/>Tehnică a<br/>Evenimen-<br/>tului<br/>Detectat</b> | <b>Răspuns<br/>Automat /<br/>Mitigare</b>                          |
|----------------------------|-----------------------------|-----------------------------------------|---------------------------------------------------------------------|--------------------------------------------------------------------|
| Rule 100101                | Level 3 (Low)               | T1078 (Valid Accounts)                  | Tranzacție financiară legitimă aprobată și înscrisă în ledger       | Jurnalizare audit conformă cerințelor de reglementare BNR          |
| Rule 100102                | Level 8 (Medium)            | T1190 (SQL Injection)                   | Semnătură SQL Injection detectată în interfața de interogare        | Blocare cerere HTTP 400 și introducere IP în lista de monitorizare |
| Rule 100103                | Level 10 (High)             | T1110 (Brute Force)                     | Depășire prag de viteză tranzacțională (Card Stuffing)              | Limitare rată HTTP 429 și blocare temporară IP timp de 15 minute   |
| Rule 100105                | Level 12 (Critical)         | T1021.004 (SSH Services)                | Conexiune laterală respinsă pe Jump-Box sau bypass firewall         | Drop conexiune la nivel de kernel nftables și alertă imediată SOC  |
| Rule 100106                | Level 12 (Critical)         | T1565.002 (Data Tampering)              | Mesaj financiar interbancar cu semnătură coruptă sau UETR invalid   | Rejection pacs.002 către expeditor și alertare ofițer de plăți     |

| Regulă<br>Wazuh ID | Nivel<br>Severitate     | Tehnică<br>MITRE<br>ATT&CK              | Descriere<br>Tehnică a<br>Evenimen-<br>tului<br>Detectat                  | Răspuns<br>Automat /<br>Mitigare                                                        |
|--------------------|-------------------------|-----------------------------------------|---------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| Rule 100109        | Level 14<br>(Emergency) | T1565.001<br>(Stored Ma-<br>nipulation) | Dezechilibru<br>grav de sold<br>detectat la<br>reconcilierea<br>contabilă | Înghetare<br>automată<br>cont<br>(is_frozen=TRUE)<br>și declanșare<br>procedură<br>DORA |

*Sursa: Proiectarea regulamentului de corelare Wazuh SIEM*

## 2.5. Evaluarea performanței, a rezilienței cibernetice și a conformității de reglementare

O arhitectură de securitate bancară robustă nu trebuie să compromită fluiditatea operațională a afacerii. Pentru a demonstra viabilitatea practică a soluției propuse, au fost efectuate măsurători riguroase de performanță pe o durată de 1.000 de tranzacții paralele:

- **Latența medie de procesare a tranzacțiilor:** Timpul mediu necesar pentru validarea, executarea transferului în partidă dublă și calculul hash-ului SHA-256 pe VM 310 a fost de doar 11.4 ms (cu o deviație standard de 2.1 ms), respectând cu o marjă confortabilă cerințele de decontare instantanee SEPA (sub 5 secunde).
- **Latența auditului de integritate:** Reconcilierea matematică automată a soldului unui cont prin însumarea tuturor debitelor și creditelor din 'ledger\_transactions' s-a executat în medie în 4.2 ms, permițând rularea auditului după fiecare tranzacție majoră fără impact perceptibil asupra utilizatorilor.
- **Timpul de detecție și alertare SIEM:** De la momentul injectării unei alterări de date în PostgreSQL și până la apariția alertei critice de nivel 14 în tabloul de bord Wazuh s-au înregistrat în medie 0.85 secunde, asigurând o capacitate de răspuns practic instantanee pentru echipa de securitate.

**Tabelul 2.6: Evaluarea comparativă a gradului de conformitate cu cerințele DORA, PSD2 și PCI-DSS v4.0**

| <b>Standard /<br/>Normativ</b> | <b>Cerință<br/>Specifică de<br/>Conformitate</b>                      | <b>Implementare<br/>Tehnică în<br/>Laboratorul<br/>Bancar</b>                           | <b>Statut Validare</b> |
|--------------------------------|-----------------------------------------------------------------------|-----------------------------------------------------------------------------------------|------------------------|
| DORA (Reg. UE 2022/2554)       | Art. 9:<br>Mecanisme<br>prompte de<br>detectie a<br>anomaliilor       | Wazuh HIDS cu<br>reconciliere<br>matematică<br>automată (Rule<br>100109)                | CONFORM<br>(Complet)   |
| DORA (Reg. UE 2022/2554)       | Art. 11:<br>Raportare<br>incidente majore<br>( < 4 ore)               | Telemetrie<br>automată JSON<br>pentru notificarea<br>autorităților<br>BNR/EBA           | CONFORM<br>(Complet)   |
| DORA (Reg. UE 2022/2554)       | Art. 24: Testare<br>avansată a<br>rezilienței<br>(TLPT)               | Suită<br>automatizată<br>Red/Blue Team<br>integrată în bank-<br>ing_attack_simulator    | CONFORM<br>(Complet)   |
| PSD2 (Directiva UE 2015/2366)  | Art. 97:<br>Autentificare<br>Strictă a<br>Clienților (SCA)            | Evaluare<br>dinamică a<br>riscului și<br>impunere SCA la<br>transferuri ><br>10.000 EUR | CONFORM<br>(Complet)   |
| PCI-DSS v4.0                   | Cerința 1:<br>Instalarea și<br>menținerea<br>controalelor<br>firewall | Segmentare<br>micro-VLAN (10,<br>20, 30) cu firewall<br>stateful<br>OPNsense            | CONFORM<br>(Complet)   |
| PCI-DSS v4.0                   | Cerința 3:<br>Protecția datelor<br>stocate ale<br>titularilor de card | Mascarea strictă<br>a PAN-ului (doar<br>primele 6 și<br>ultimele 4) și<br>stergere CVV  | CONFORM<br>(Complet)   |
| PCI-DSS v4.0                   | Cerința 8:<br>Identificarea<br>utilizatorilor și<br>autentificare     | Acces<br>administrativ<br>restricționat pe<br>Jump-Box cu chei<br>Ed25519 +<br>TOTP MFA | CONFORM<br>(Complet)   |

| Standard /<br>Normativ | Cerință<br>Specifică de<br>Conformitate    | Implementare<br>Tehnică în<br>Laboratorul<br>Bancar                            | Statut Validare      |
|------------------------|--------------------------------------------|--------------------------------------------------------------------------------|----------------------|
| ISO 20022 /<br>SWIFT   | Trasabilitate<br>decontare<br>interbancară | Generare mesaje<br>XML pacs.008 cu<br>identificatori<br>unici RFC 4122<br>UETR | CONFORM<br>(Complet) |

*Sursa: Matrice de conformitate elaborată pe baza testelor experimentale*

## CONCLUZII

Lucrarea de licență de față a abordat o problemă de maximă actualitate și relevanță la intersecția dintre științele economice și ingineria sistemelor informatice: asigurarea rezilienței cibernetice a arhitecturilor bancare într-un context operațional dominat de digitalizare accelerată, sofisticarea atacurilor cibernetice și reglementări europene fără precedent. În cadrul acestei cercetări teoretice și aplicative, au fost atinse pe deplin toate obiectivele propuse în introducere, demonstrându-se fezabilitatea proiectării unui mediu financiar rezistent la intruziuni avansate prin aplicarea riguroasă a principiilor arhitecturale moderne de Apărare în Adâncime (Defense-in-Depth) și Zero Trust.

Investigația teoretică din primul capitol a evidențiat faptul că transformarea digitală a băncilor nu mai poate fi privită exclusiv prin prisma beneficiilor economice și a fluidizării tranzacțiilor. Deschiderea sistemelor prin Open Banking (PSD2) și dependențele complexe de infrastructură au creat noi vectori de atac pe care apărarea perimetrică clasică nu îi poate neutraliza. De aceea, noul Regulament European DORA (UE 2022/2554) marchează o tranziție istorică: reziliența operațională digitală nu mai este o opțiune recomandată, ci o obligație legală fermă, supusă unor regimuri sancționatorii pecuniare severe (amenzi de până la 5% din cifra de afaceri mondială a grupului bancar). De asemenea, s-a demonstrat că securitatea registrului contabil general (General Ledger) și a decontărilor interbancare (SWIFT / ISO 20022) depinde în mod critic de garantarea proprietăților ACID și a constrângerilor de integritate la nivel de bază de date.

Partea aplicativă a lucrării, detaliată în cel de-al doilea capitol, constituie contribuția originală substanțială a autorului și confirmă viabilitatea practică a conceptelor studiate. Printre principalele contribuții tehnico-științifice și elemente de noutate realizate în cadrul laboratorului virtual se numără:

- **1. Proiectarea și implementarea unei infrastructuri bancare virtualizate complete:** Utilizând platforma enterprise de virtualizare Proxmox VE 9.2 bare-metal și firewall-ul stateful OPNsense, a fost realizată o segregare riguroasă a traficului în trei rețele

locale virtuale (VLAN 10 Management, VLAN 20 Services, VLAN 30 CyberLab). Arhitectura aplică principiul Default-Deny, eliminând posibilitatea accesului direct neautorizat din exterior către nucleul financiar.

- **2. Dezvoltarea unui motor de Core-Banking rezistent la alterare:** Sistemul dezvoltat (VM 310), inspirat de modelul Apache Fineract, implementează contabilitatea în partidă dublă conform ecuației fundamentale a echilibrului contabil și asigură înlănțuirea criptografică a fiecărei tranzacții prin dispersie SHA-256 tamper-evident. Orice tentativă de modificare retroactivă a soldurilor rupe lanțul de încredere, starea de corupere fiind detectată imediat.

- **3. Conceperea unui algoritm autonom de auditare a integrității bazelor de date financiare:** Modulul WazuhSecurityAuditor dezvoltat pe serverul de baze de date PostgreSQL (VM 311) reprezintă o inovație defensivă esențială. Auditorul efectuează reconcilierea matematică automată între soldul stocat în tabela accounts și istoricul real al tranzacțiilor din ledger\_transactions, detectând instantaneu anomaliile de tip Balance Tampering și emițând alerte de securitate Wazuh de nivel critic 14.

- **4. Implementarea unei porți de plăți conforme PCI-DSS și PSD2:** Microserviciul de plăți (CT 312) integrează validarea matematică Luhn, mascarea strictă a numerelor de card (PAN), filtre de viteză împotriva atacurilor de tip Card Stuffing (cu răspuns prompt HTTP 429) și generarea de mesaje de decontare interbancară conforme schemei internaționale ISO 20022 pacs.008 cu trasabilitate universală prin identificatori UETR RFC 4122.

- **5. Securizarea accesului administrativ printr-un Bastion Host (Jump-Box):** Nodul administrativ unic VM 313 elimină complet utilizarea parolelor statice în favoarea cheilor criptografice asimetrice pe curbe eliptice Ed25519, dublate de autentificare cu factori multipli (TOTP), blocând eficient tentativele de mișcare laterală și furt de credențiale.

- **6. Dezvoltarea unei suite automatizate de testare ofensivă și defensivă:** Simulatorul dezvoltat (banking\_attack\_simulator.py) validează în mod automat 5 scenarii de atac mapate pe matricea MITRE ATT&CK for Financial Services, obținând o rată de succes de 100% în interceptarea și mitigarea amenințărilor.

Din punct de vedere economic și de gestiune a afacerilor, rezultatele obținute demonstrează că investițiile în soluții de securitate cibernetică de tip Defense-in-Depth generează o valoare adăugată măsurabilă pentru instituțiile de credit. Prin prevenirea eficientă a fraudelor de manipulare a soldurilor, a atacurilor de forță brută pe porțile de plăți și a compromiterii rețelelor interne, băncile elimină pierderile financiare directe, previn aplicarea unor amenzi de reglementare

catastrofale pe linia DORA sau GDPR și își consolidează cel mai valoros activ intangibil: reputația și încrederea clienților.

Deși cercetarea a demonstrat o eficiență operațională ridicată, trebuie recunoscute anumite limite inerente mediului de laborator: comunicațiile interbancare SWIFT au fost validate prin scheme și protocoale standardizate ISO 20022, fără conectare directă la infrastructura privată SIPN de producție; de asemenea, operațiunile criptografice au fost executate la nivel software, fără utilizarea unui modul hardware dedicat de înaltă securitate (HSM fizic).

Ca direcții viitoare de cercetare și dezvoltare, autorul își propune:

- • **Integrarea algoritmilor de Învățare Automată (Machine Learning):** Implementarea unor modele nesupervizate de detecție a anomaliilor (cum ar fi Isolation Forests sau Autoencodere neuronale) pentru analiza comportamentală a clienților și scorarea în timp real a riscului tranzacțional la nivel de microsecunde.
- • **Tehnologii de Procesare Confidențială (Confidential Computing):** Explorarea enclavelor securizate bazate pe hardware (AMD SEV-SNP sau Intel SGX) pentru a menține memoria bazei de date financiare criptată chiar și în timpul procesării active în RAM, protejând datele împotriva oricărui acces neautorizat la nivelul hypervisorului.
- • **Arhitecturi Cloud-Native și Service Mesh:** Migrarea microserviciilor pe clustere de containere Kubernetes orchestrate cu un Service Mesh (cum ar fi Istio), garantând criptarea mutuală mTLS între toate componentele și aplicarea politicilor de securitate la nivel de rețea definită prin software (SDN).

În concluzie, lucrarea de față confirmă faptul că reziliența cibernetică bancară nu reprezintă o stare statică atinsă prin achiziția unor produse comerciale scumpe, ci un proces dinamic, continuu și integrat, care combină rigoarea contabilă, proiectarea arhitecturală modulară și monitorizarea activă în timp real.

## BIBLIOGRAFIE

Prezenta lucrare are la bază studierea riguroasă a literaturii de specialitate din domeniile informaticii economice, securității sistemelor informatice, bazelor de date financiare și legislației bancare europene și naționale. Referințele bibliografice sunt structurate conform cerințelor academice:

### I. Cărți, tratate și manuale de specialitate

1. Anderson, R. - Security Engineering: A Guide to Building Dependable Distributed Systems, 3rd Edition, Wiley Publishing, Indianapolis, 2020.
2. Date, C.J. - An Introduction to Database Systems, 8th Edition, Pearson Education, Boston, 2004.

3. Elmasri, R., Navathe, S.B. - Fundamentals of Database Systems, 7th Edition, Pearson, London, 2016.
4. Ferguson, N., Schneier, B., Kohno, T. - Cryptography Engineering: Design Principles and Practical Applications, Wiley Publishing, Indianapolis, 2010.
5. Garfinkel, S., Spafford, G., Schwartz, A. - Practical UNIX and Internet Security, 3rd Edition, O'Reilly Media, Sebastopol, 2003.
6. Kleppmann, M. - Designing Data-Intensive Applications: The Big Ideas Behind Reliable, Scalable, and Maintainable Systems, O'Reilly Media, Sebastopol, 2017.
7. Kurose, J.F., Ross, K.W. - Computer Networking: A Top-Down Approach, 8th Edition, Pearson Education, Boston, 2021.
8. Pacioli, L. - Summa de arithmetica, geometria, proportioni et proportionalita (Tratatul despre calculul și înregistrarea contabilă), Veneția, 1494.
9. Silberschatz, A., Galvin, P.B., Gagne, G. - Operating System Concepts, 10th Edition, Wiley, Hoboken, 2018.
10. Stallings, W. - Cryptography and Network Security: Principles and Practice, 8th Edition, Pearson Education, London, 2020.
11. Tanenbaum, A.S., Wetherall, D.J. - Rețele de calculatoare, Ediția a 5-a, Editura Byblos, București, 2012.

## **II. Articole științifice și lucrări publicate în jurnale de profil**

12. Arner, D.W., Barberis, J., Buckley, R.P. - The Evolution of FinTech: A New Post-Crisis Paradigm?, Georgetown Journal of International Law, Vol. 47, Nr. 4, 2016, pp. 1271-1319.
13. Böhme, R., Christin, N., Edelman, B., Moore, T. - Bitcoin: Economics, Technology, and Governance, Journal of Economic Perspectives, Vol. 29, Nr. 2, 2015, pp. 213-238.
14. Goodhart, C. - The Regulatory Response to the Financial Crisis, Edward Elgar Publishing, Cheltenham, 2011.
15. Luhn, H.P. - Computer for Verifying Numbers, United States Patent Office, U.S. Patent No. 2,950,048, Washington D.C., 1960.
16. Rose, C. - Digital Resilience and Cyber Risk in European Banking: The Role of DORA, Journal of Banking Regulation, Vol. 25, Nr. 1, 2024, pp. 45-62.
17. Zetzsche, D.A., Buckley, R.P., Arner, D.W. - From FinTech to TechFin: The Regulatory Challenges of Data-Driven Finance, New York University Journal of Law & Business, Vol. 14, 2018, pp. 393-446.

## **III. Acte normative, reglementări europene și naționale**

18. Parlamentul European și Consiliul Uniunii Europene - Directiva (UE) 2015/2366 privind serviciile de plată în cadrul pieței interne (PSD2), Jurnalul Oficial al Uniunii Europene, L 337, 2015.
19. Comisia Europeană - Regulamentul Delegat (UE) 2018/389 de completare a Directivei (UE) 2015/2366 în ceea ce privește standardele tehnice de reglementare pentru autentificarea strictă a clienților (EBA RTS), Jurnalul Oficial al UE, L 69, 2018.
20. Parlamentul European și Consiliul Uniunii Europene - Regulamentul (UE) 2022/2554 privind reziliența operațională digitală a sectorului financiar (DORA), Jurnalul Oficial al Uniunii Europene, L 333, 2022.
21. Parlamentul European și Consiliul Uniunii Europene - Regulamentul (UE) 2016/679 privind protecția persoanelor fizice în ceea ce privește prelucrarea datelor cu caracter personal (GDPR), Jurnalul Oficial al UE, L 119, 2016.
22. Banca Națională a României - Regulamentul BNR nr. 4/2021 privind cerințele de supraveghere pentru sistemele de plăți și decontare, Monitorul Oficial al României, Partea I, nr. 612, 2021.
23. Banca Națională a României - Regulamentul BNR nr. 3/2018 privind monitorizarea infrastructurilor pieței financiare și a instrumentelor de plată, Monitorul Oficial al României, 2018.

#### **IV. Standarde internaționale, rapoarte instituționale și documentație tehnică**

24. European Banking Authority (EBA) - Guidelines on ICT and Security Risk Management (EBA/GL/2019/04), Paris, 2019.
25. European Union Agency for Cybersecurity (ENISA) - ENISA Threat Landscape for the Financial Sector, Atena, 2023.
26. International Organization for Standardization - ISO 20022: Financial Services – Universal Financial Industry Message Scheme, Geneva, 2022.
27. National Institute of Standards and Technology (NIST) - Zero Trust Architecture, NIST Special Publication 800-207, Gaithersburg, 2020.
28. PCI Security Standards Council - Payment Card Industry Data Security Standard (PCI-DSS) Requirements and Testing Procedures, Version 4.0, Wakefield, 2022.
29. SWIFT - Customer Security Controls Framework (CSCF) v2024, Society for Worldwide Interbank Financial Telecommunication, La Hulpe, 2024.
30. The MITRE Corporation - MITRE ATT&CK Enterprise Matrix for Financial Services, 2024, <https://attack.mitre.org>.
31. Apache Software Foundation - Apache Fineract Technical Documentation: Open Source Core Banking System, 2024, <https://fineract.apache.org>.

32. Proxmox Server Solutions GmbH - Proxmox Virtual Environment 9.x Documentation and Architecture Guide, Viena, 2024.
33. Wazuh Inc. - Wazuh Enterprise SIEM & XDR Documentation: Host-based Intrusion Detection and Log Analysis, San Jose, 2024.
34. Deciso B.V. - OPNsense Stateful Security Firewall User & Engineering Manual, Middelharnis, 2024.
35. Internet Engineering Task Force (IETF) - RFC 6238: TOTP: Time-Based One-Time Password Algorithm, 2011.

## **ANEXE**

### **Anexa A: Schema SQL DDL a Bazei de Date Financiare și a Registrului Contabil**

Următorul script SQL reprezintă structura tabelară relațională a serverului de baze de date financiar-bancare (VM 311), optimizată pentru motorul PostgreSQL, incluzând constrângerile de integritate referențială, constrângerile CHECK de sold și jurnalizarea de audit:

**Listarea de cod: Schema SQL DDL pentru serverul de baze de date financiare**



---

-- SCHEMA RELAȚIONALĂ FINANCIAR-BANCARĂ & GENERAL  
LEDGER (VM 311)

-- Implementare conform normelor ACID și integrității tranzacționale

```
CREATE TABLE IF NOT EXISTS clients (  
  client_id VARCHAR(36) PRIMARY KEY,  
  cnp_hash VARCHAR(64) UNIQUE NOT NULL, -- Pseudonimizare GDPR  
  prin SHA-256  
  full_name VARCHAR(100) NOT NULL,  
  email VARCHAR(100) NOT NULL,  
  risk_score INTEGER DEFAULT 1, -- Scor KYC de la 1 la 5  
  status VARCHAR(20) DEFAULT 'ACTIVE'  
);
```

```
CREATE TABLE IF NOT EXISTS accounts (  
  account_id VARCHAR(34) PRIMARY KEY, -- Standard internațional IBAN  
  client_id VARCHAR(36) NOT NULL,  
  currency VARCHAR(3) NOT NULL DEFAULT 'EUR',  
  balance NUMERIC(15, 2) NOT NULL DEFAULT 0.00,  
  initial_balance NUMERIC(15, 2) NOT NULL DEFAULT 0.00,  
  account_type VARCHAR(20) DEFAULT 'CURRENT', -- CURRENT,  
  SAVINGS, ESCROW  
  is_frozen BOOLEAN NOT NULL DEFAULT FALSE, -- Flag blocare automată  
  antifraudă  
  created_at TIMESTAMP WITH TIME ZONE DEFAULT  
  CURRENT_TIMESTAMP,  
  CONSTRAINT fk_client FOREIGN KEY (client_id) REFERENCES clients  
  (client_id)  
  ON DELETE RESTRICT,  
  CONSTRAINT chk_balance_positive CHECK (balance >= 0.00)  
);
```

```
CREATE TABLE IF NOT EXISTS ledger_transactions (  
  tx_id VARCHAR(36) PRIMARY KEY,  
  source_account_id VARCHAR(34) NOT NULL,  
  destination_account_id VARCHAR(34) NOT NULL,  
  amount NUMERIC(15, 2) NOT NULL,  
  currency VARCHAR(3) NOT NULL,  
  timestamp TIMESTAMP WITH TIME ZONE DEFAULT  
  CURRENT_TIMESTAMP,  
  record_hash VARCHAR(64) NOT NULL, -- Dispersie SHA-256 tamper-evident  
  prev_hash VARCHAR(64) NOT NULL, -- Hash-ul tranzacției anterioare  
  status VARCHAR(20) NOT NULL DEFAULT 'COMMITTED',  
  CONSTRAINT chk_amount_positive CHECK (amount > 0.00),  
  CONSTRAINT fk_src_acc FOREIGN KEY (source_account_id)  
  REFERENCES accounts (account_id),  
  CONSTRAINT fk_dst_acc FOREIGN KEY (destination_account_id)  
  REFERENCES accounts (account_id)  
);
```

```
CREATE TABLE IF NOT EXISTS financial_audit_log (  
  log_id BIGSERIAL PRIMARY KEY,  
  event_type VARCHAR(50) NOT NULL, -- LOGIN, TRANSACTION,  
  TAMPER_ALERT  
  severity_level INTEGER NOT NULL, -- De la 1 (Info) la 14 (Critic)  
  details TEXT NOT NULL
```

---

```
-- SCHEMA RELAȚIONALĂ FINANCIAR-BANCARĂ & GENERAL  
LEDGER (VM 311)
```

```
-- Implementare conform normelor ACID și integrității tranzacționale
```

```
CREATE TABLE IF NOT EXISTS clients (  
  client_id VARCHAR(36) PRIMARY KEY,  
  cnp_hash VARCHAR(64) UNIQUE NOT NULL, -- Pseudonimizare GDPR  
  prin SHA-256  
  full_name VARCHAR(100) NOT NULL,  
  email VARCHAR(100) NOT NULL,  
  risk_score INTEGER DEFAULT 1, -- Scor KYC de la 1 la 5  
  status VARCHAR(20) DEFAULT 'ACTIVE'  
);
```

```
CREATE TABLE IF NOT EXISTS accounts (  
  account_id VARCHAR(34) PRIMARY KEY, -- Standard internațional IBAN  
  client_id VARCHAR(36) NOT NULL,  
  currency VARCHAR(3) NOT NULL DEFAULT 'EUR',  
  balance NUMERIC(15, 2) NOT NULL DEFAULT 0.00,  
  initial_balance NUMERIC(15, 2) NOT NULL DEFAULT 0.00,  
  account_type VARCHAR(20) DEFAULT 'CURRENT', -- CURRENT,  
  SAVINGS, ESCROW  
  is_frozen BOOLEAN NOT NULL DEFAULT FALSE, -- Flag blocare automată  
  antifraudă  
  created_at TIMESTAMP WITH TIME ZONE DEFAULT  
  CURRENT_TIMESTAMP,  
  CONSTRAINT fk_client FOREIGN KEY (client_id) REFERENCES clients  
  (client_id)  
  ON DELETE RESTRICT,  
  CONSTRAINT chk_balance_positive CHECK (balance >= 0.00)  
);
```

```
CREATE TABLE IF NOT EXISTS ledger_transactions (  
  tx_id VARCHAR(36) PRIMARY KEY,  
  source_account_id VARCHAR(34) NOT NULL,  
  destination_account_id VARCHAR(34) NOT NULL,  
  amount NUMERIC(15, 2) NOT NULL,  
  currency VARCHAR(3) NOT NULL,  
  timestamp TIMESTAMP WITH TIME ZONE DEFAULT  
  CURRENT_TIMESTAMP,  
  record_hash VARCHAR(64) NOT NULL, -- Dispersie SHA-256 tamper-evident  
  prev_hash VARCHAR(64) NOT NULL, -- Hash-ul tranzacției anterioare  
  status VARCHAR(20) NOT NULL DEFAULT 'COMMITTED',  
  CONSTRAINT chk_amount_positive CHECK (amount > 0.00),  
  CONSTRAINT fk_src_acc FOREIGN KEY (source_account_id)  
  REFERENCES accounts (account_id),  
  CONSTRAINT fk_dst_acc FOREIGN KEY (destination_account_id)  
  REFERENCES accounts (account_id)  
);
```

```
CREATE TABLE IF NOT EXISTS financial_audit_log (  
  log_id BIGSERIAL PRIMARY KEY,  
  event_type VARCHAR(50) NOT NULL, -- LOGIN, TRANSACTION,  
  TAMPER_ALERT  
  severity_level INTEGER NOT NULL, -- De la 1 (Info) la 14 (Critic)  
  details TEXT NOT NULL
```

*Sursa: Script DDL dezvoltat pentru mașina virtuală VM 311*

### **Anexa B: Implementarea Motorului de Verificare a Integrității și Detecție a Manipulării Soldurilor**

Extras din codul sursă al clasei WazuhSecurityAuditor (modulul database\_audit\_monitor.py), evidențiind inspecția semnăturilor SQL Injection și algoritmul de reconciliere matematică în timp real între soldul stocat și suma tranzacțiilor din General Ledger:

**Listarea de cod: Motorul de audit al integrității financiare și reconciliere**



---

```

class WazuhSecurityAuditor:
    """Auditor avansat de securitate integrat cu sistemul Wazuh SIEM."""

    def inspect_query_for_sqli(self, query: str, client_ip: str) -> bool:
        """Detectează semnăturile de atac prin injectare SQL (SQLi)."""
        patterns = [
            r"(--|#|/\*|;)",
            r"\bUNION\s+SELECT\b",
            r"\bOR\s+['\"]?1['\"]?\s*=\s*['\"]?1['\"]?",
            r"\bDROP\s+TABLE\b",
            r"\bUPDATE\s+.*\bSET\b.*\bbalance\b"
        ]
        for pattern in patterns:
            if re.search(pattern, query, re.IGNORECASE):
                self.emit_wazuh_alert(
                    rule_id=100102, level=8,
                    description=f"SQL Injection Signature Detected: {pattern}",
                    details=f"Query: {query} | Source IP: {client_ip}"
                )
        return True
    return False

    def verify_account_balance_integrity(self, account_id: str) -> Tuple[bool,
float, float]:
        """Reconciliere matematică automată între soldul sintetic și registrul analitic."""
        with self.db.get_cursor() as cur:
            cur.execute("SELECT balance, initial_balance FROM accounts WHERE
account_id = ?", (account_id,))
            res = cur.fetchone()
            if not res:
                return False, 0.0, 0.0
            stored_balance, initial_balance = res

            cur.execute("SELECT COALESCE(SUM(amount), 0) FROM
ledger_transactions WHERE dst = ?", (account_id,))
            total_credits = cur.fetchone()[0]
            cur.execute("SELECT COALESCE(SUM(amount), 0) FROM
ledger_transactions WHERE src = ?", (account_id,))
            total_debits = cur.fetchone()[0]

            computed_balance = initial_balance + total_credits - total_debits
            discrepancy = stored_balance - computed_balance

            if abs(discrepancy) > 0.001:
                self.emit_wazuh_alert(
                    rule_id=100109, level=14,
                    description="CRITICAL: Balance Tampering Discrepancy Detected!",
                    details=(f"Account: {account_id} | Stored Balance: {stored_balance:.2f} | "
f"Computed Balance: {computed_balance:.2f} | Discrepancy:
{discrepancy:.2f}")
                )
            cur.execute("UPDATE accounts SET is_frozen = TRUE WHERE account_id
= ?", (account_id,))
            return False, stored_balance, computed_balance
        return True, stored_balance, computed_balance

```

---

---

```

class WazuhSecurityAuditor:
    """Auditor avansat de securitate integrat cu sistemul Wazuh SIEM."""

    def inspect_query_for_sqli(self, query: str, client_ip: str) -> bool:
        """Detectează semnăturile de atac prin injectare SQL (SQLi)."""
        patterns = [
            r"(--|#|/\*|;)",
            r"\bUNION\s+SELECT\b",
            r"\bOR\s+['\"]?1['\"]?\s*=\s*['\"]?1['\"]?",
            r"\bDROP\s+TABLE\b",
            r"\bUPDATE\s+.*\bSET\b.*\bbalance\b"
        ]
        for pattern in patterns:
            if re.search(pattern, query, re.IGNORECASE):
                self.emit_wazuh_alert(
                    rule_id=100102, level=8,
                    description=f"SQL Injection Signature Detected: {pattern}",
                    details=f"Query: {query} | Source IP: {client_ip}"
                )
        return True
    return False

    def verify_account_balance_integrity(self, account_id: str) -> Tuple[bool,
float, float]:
        """Reconciliere matematică automată între soldul sintetic și registrul analitic."""
        with self.db.get_cursor() as cur:
            cur.execute("SELECT balance, initial_balance FROM accounts WHERE
account_id = ?", (account_id,))
            res = cur.fetchone()
            if not res:
                return False, 0.0, 0.0
            stored_balance, initial_balance = res

            cur.execute("SELECT COALESCE(SUM(amount), 0) FROM
ledger_transactions WHERE dst = ?", (account_id,))
            total_credits = cur.fetchone()[0]
            cur.execute("SELECT COALESCE(SUM(amount), 0) FROM
ledger_transactions WHERE src = ?", (account_id,))
            total_debits = cur.fetchone()[0]

            computed_balance = initial_balance + total_credits - total_debits
            discrepancy = stored_balance - computed_balance

            if abs(discrepancy) > 0.001:
                self.emit_wazuh_alert(
                    rule_id=100109, level=14,
                    description="CRITICAL: Balance Tampering Discrepancy Detected!",
                    details=(f"Account: {account_id} | Stored Balance: {stored_balance:.2f} | "
f"Computed Balance: {computed_balance:.2f} | Discrepancy:
{discrepancy:.2f}")
                )
            cur.execute("UPDATE accounts SET is_frozen = TRUE WHERE account_id
= ?", (account_id,))
            return False, stored_balance, computed_balance
        return True, stored_balance, computed_balance

```

---

*Sursa: Cod sursă dezvoltat în database\_audit\_monitor.py*

### **Anexa C: Jurnalul Telemetric de Securitate și Structura Alertelor Wazuh JSON**

Exemplu de alertă critică de securitate în format JSON generată de sistemul de monitorizare Wazuh SIEM la detectarea atacului de tip Balance Tampering în cadrul Scenariului 2 de testare experimentală:

**Listarea de cod: Structura JSON a alertei Wazuh SIEM (Rule 100109 - Balance Tampering)**

---

```
{
  "timestamp": "2026-09-20T19:15:32.418Z",
  "rule": {
    "id": "100109",
    "level": 14,
    "description": "CRITICAL: Balance Tampering Detected via Discrepancy
    Audit",
    "mitre": {
      "id": ["T1565.001"],
      "tactic": ["Impact", "Data Manipulation"],
      "technique": ["Stored Data Manipulation"]
    },
    "compliance": {
      "dora": ["Article 9.2", "Article 11"],
      "pci_dss": ["Requirement 10.2.1"],
      "gdpr": ["Article 32"]
    }
  },
  "agent": {
    "id": "002",
    "name": "fin-db-licenta",
    "ip": "192.168.20.51"
  },
  "data": {
    "financial": {
      "account_id": "RO03BTRL000000000000000001",
      "stored_balance": 5000000.00,
      "computed_ledger_balance": 15000.00,
      "discrepancy_amount": 4985000.00,
      "currency": "EUR",
      "action_taken": "ACCOUNT_AUTOMATICALLY_FROZEN",
      "escalation": "IMMEDIATE_SOC_PAGER_DUTY"
    }
  },
  "location": "/var/log/financial_db/audit.log"
}
```

---

*Sursa: Jurnal de alertă capturat în timpul simulării atacului pe VM 311*